République du Cameroun

Université de Garoua

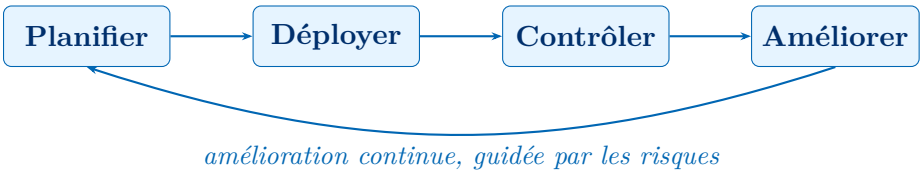
Faculté des Sciences · Département de Mathématiques et Informatiques

Master Professionnel en Sécurité des Systèmes Informatiques et des Données

Systèmes de Gestion de la Sécurité Informatique

Du risque à la certification :
piloter la sécurité de l'information

SGSI - UE SIS498



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | Université de Garoua

Faculté des Sciences · Département de Mathématiques et Informatiques

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE SIS498

AVANT-PROPOS

Ce livre est le support de l'unité d'enseignement **SIS498, Systèmes de Gestion de la Sécurité Informatique**, du Master Professionnel en Sécurité des Systèmes Informatiques et des Données de l'Université de Garoua (Faculté des Sciences, Département de Mathématiques et Informatiques).

Là où d'autres enseignements apprennent à détecter, à investiguer ou à attaquer, **SIS498** apprend à **décider** la sécurité et à la **tenir dans la durée** : gouverner, apprécier les risques, mettre en œuvre les mesures, contrôler et améliorer. Le fil conducteur est unique : la **mairie d'Eséka**, dans le département du Nyong-et-Kéllé, décide, après un incident, de bâtir un système de management de la sécurité de l'information et de le conduire jusqu'à la certification. Le cours suit cette démarche à travers quatre phases situées dans la région : **NYONG** (gouvernance), **KELLÉ** (risques), **MAKAK** (mise en œuvre) et **MATOMB** (audit).

Chaque notion est ancrée à la fois dans les standards internationaux (famille **ISO/IEC 27000**, en particulier 27001, 27002 et 27005, ISO 31000, ISO 22301, ISO 19011, NIST CSF, EBIOS Risk Manager) et dans le droit camerounais et africain (lois n° 2010/012 et 2024/017, Convention de Malabo). Un fil directeur parcourt le livre : le cycle **PDCA** (planifier, déployer, contrôler, agir), par lequel un système de management se construit et s'améliore.

Les cas sont fictifs : les noms, les dates et les montants le sont ; les mécanismes de gestion et les références normatives sont exacts. Le livre s'accompagne de l'environnement **NDAP SUKULU**, qui fait pratiquer chaque chapitre.



© MaletYon

MODE D'EMPLOI

À qui s'adresse ce cours

Aux étudiants du Master Professionnel en Sécurité des Systèmes Informatiques et des Données, et aux professionnels qui exercent ou se destinent aux métiers de **RSSI**, de **DSI**, de **délégué à la protection des données** (DPO), d'**auditeur de SMSI** et de **responsable conformité**. Des notions de réseaux, de systèmes et de droit numérique sont utiles.

Comment lire ce livre

Le livre comprend un prologue et six parties. Chaque chapitre suit le même plan : une épigraphe, le niveau et les prérequis, les objectifs, une question directrice, cinq sections, un encadré « à retenir », dix exercices gradués et une transition. Les niveaux des exercices sont signalés par des étoiles : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert.

Les encadrés

- **Scénario opérationnel** : un épisode des opérations NYONG, KELLÉ, MAKAK ou MATOMB, avec *constatation* (faits) et *analyse* (interprétation, niveau de confiance).
- **Actif** : la fiche d'un actif informationnel (valeur, support, critères de sécurité prioritaires).
- **Mesure** : une mesure de sécurité, son objectif et sa mise en œuvre.
- **Application métier** : ce que le chapitre change pour un métier.
- **Cadre juridique** : le texte de droit applicable.

Constatation et analyse

Le cours distingue systématiquement ce que l'on **constate** (un fait vérifiable, une preuve) de ce que l'on en **déduit** (une interprétation, assortie d'un niveau de confiance). C'est la discipline première du management de la sécurité et de l'audit.

NDAP SUKULU et évaluation

L'environnement compagnon NDAP SUKULU (page suivante) propose, pour chaque chapitre, une fiche d'auto-évaluation et, pour les chapitres pratiques, un lab sur pièces. Fiches et labs se font hors des 30 heures de cours. Le code du cours est **SIS498**.

© *MaletYon*

NDAP SUKULU, L'ENVIRONNEMENT COMPAGNON



Ndap sukulu signifie « la salle de classe » en bassa, et *Malet Yon*, « ton enseignant ». **NDAP SUKULU** est l'environnement compagnon du cours : pour chaque chapitre, une fiche d'auto-évaluation de 40 questions, corrigée automatiquement ; pour les chapitres pratiques, un lab sur pièces (inventaires d'actifs, registres de risques, extraits de politique, tableaux de bord) dans un cadre entièrement fermé ; et un tableau de bord de progression.

On y accède par le code de cours **SIS498**. Les fiches et les labs se font hors des 30 heures de cours. Les pièces des labs sont fictives et établies pour l'enseignement.

Les dix labs de NDAP SUKULU

Lab	Sujet	Ch.
SGSI-LAB-01	Inventaire et classification des actifs	1
SGSI-LAB-02	Rédiger une politique de sécurité	5
SGSI-LAB-03	Analyse d'écart ISO 27001 (gap analysis)	8
SGSI-LAB-04	Appréciation des risques (EBIOS Risk Manager)	12
SGSI-LAB-05	Matrice et traitement des risques	13
SGSI-LAB-06	Construire une déclaration d'applicabilité	14
SGSI-LAB-07	Contrôle d'accès et moindre privilège (RBAC)	16
SGSI-LAB-08	Plan de continuité et sauvegarde 3-2-1	17
SGSI-LAB-09	Tableau de bord d'indicateurs de sécurité	18
SGSI-LAB-10	Audit interne et non-conformités	19

Chaque lab dure environ une heure et se corrige automatiquement. Les pièces se trouvent dans le dossier `preuves` (lecture seule) et une copie de travail dans `travail`.

© *MaletYon*

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi v

NDAP SUKULU, l'environnement compagnon vii

Prologue Opérationnel 3

0 Prologue : la Décision de la Mairie 3

0.1 Réparer ne suffit pas . . . 4
0.2 La décision : un système, pas un achat . . . 4
0.3 Le fil rouge : quatre phases . . . 4
0.4 Le cœur du cours : le cycle PDCA . . . 5

I Fondements du Management de la Sécurité 7

1 Qu'est-ce que la Sécurité de l'Information 9

1.1 L'Information, un Actif . . . 10
1.2 La Triade DIC . . . 10
1.3 Les Critères Complémentaires . . . 11
1.4 Sécurité de l'Information ou Sécurité Informatique . . . 11
1.5 Lire un Incident par ses Critères . . . 11

2 Du Risque à la Décision 15

2.1 Les Enjeux . . . 16
2.2 Les Acteurs . . . 16
2.3 Le Patrimoine Informationnel . . . 17
2.4 La Sécurité, une Décision . . . 17
2.5 L'Écosystème de la Mairie . . . 17

3 Le Cycle PDCA et l'Amélioration Continue 21

3.1 Les Quatre Étapes . . . 22
3.2 Un Cycle, pas un Projet . . . 22
3.3 PDCA et Plan du Cours . . . 22
3.4 Corriger, Améliorer . . . 23
3.5 L'Amélioration Continue, une Exigence . . . 23

© *MaletYon*

II Gouvernance et Politique de Sécurité 27

4 La Gouvernance de la Sécurité 29

4.1 Gouverner et Manager . . . 30
4.2 Le RSSI . . . 30
4.3 La Direction et le Comité de Sécurité . . . 30
4.4 La Matrice de Responsabilités . . . 31
4.5 L'Engagement de la Direction . . . 31

5 La Politique de Sécurité du Système d'Information 35

5.1 Qu'est-ce qu'une Politique . . . 36
5.2 Objectifs et Portée . . . 36
5.3 La Structure Type . . . 36
5.4 Politique, Procédure, Charte . . . 37
5.5 Le Cycle de Vie du Document . . . 37

6 Chartes, Conformité et Protection des Données 41

6.1 La Charte Informatique . . . 42
6.2 Les Principes de Protection des Données . . . 42
6.3 Le Cadre Juridique Camerounais . . . 42
6.4 Le Délégué à la Protection des Données . . . 43
6.5 Sécurité et Conformité . . . 43

III Le SMSI selon ISO/IEC 27001 47

7 La Famille ISO/IEC 27000 et le SMSI 49

7.1 La Famille 27000 . . . 50
7.2 Exigences et Lignes Directrices . . . 50
7.3 Le SMSI selon la Norme . . . 50
7.4 Le Principe de la Certification . . . 51
7.5 La Mairie dans le Cadre . . . 51

8 Contexte, Leadership, Planification 55

8.1 Le Contexte (Clause 4) . . . 56
8.2 Le Domaine d'Application . . . 56
8.3 Le Leadership (Clause 5) . . . 56
8.4 La Planification (Clause 6) . . . 57
8.5 Les Objectifs de Sécurité . . . 57

9 Support, Fonctionnement, Évaluation, Amélioration 61

9.1 Le Support (Clause 7) . . . 62
9.2 Les Informations Documentées . . . 62

9.3 Le Fonctionnement (Clause 8) . . . 62
9.4 L'Évaluation des Performances (Clause 9) . . . 62
9.5 L'Amélioration (Clause 10) . . . 63

10 ISO/IEC 27002 et les Mesures de Sécurité 65

10.1 27002 et Annexe A . . . 66
10.2 Les Quatre Thèmes . . . 66
10.3 Structure d'une Mesure . . . 66
10.4 Mesures et Risques . . . 66
10.5 Vers la Déclaration d'Applicabilité . . . 67

IV L'Appréciation et le Traitement des Risques 69

11 Concepts et Vocabulaire du Risque 71

11.1 Les Cinq Notions . . . 72
11.2 La Formule du Risque . . . 72
11.3 Inhérent et Résiduel . . . 72
11.4 Appétence et Acceptation . . . 72
11.5 Un Cas Appliqué . . . 73

12 Les Méthodes d'Appréciation des Risques 75

12.1 EBIOS Risk Manager . . . 76
12.2 OCTAVE . . . 76
12.3 MEHARI . . . 76
12.4 Comparer et Choisir . . . 77
12.5 Appliquer à la Mairie . . . 77

13 Cartographie et Traitement des Risques 81

13.1 La Matrice des Risques . . . 82
13.2 Hiérarchiser . . . 82
13.3 Les Quatre Stratégies . . . 82
13.4 Choisir un Traitement . . . 83
13.5 Le Risque Résiduel . . . 83

14 La Déclaration d'Applicabilité et le Plan de Traitement 87

14.1 Rôle de la DdA . . . 88
14.2 Construire la DdA . . . 88
14.3 DdA et Plan de Traitement . . . 88
14.4 Inclure, Exclure . . . 88
14.5 Acter le Risque Résiduel . . . 89

V Mettre en Œuvre les Mesures 91

15 Mesures Organisationnelles et Humaines 93

15.1 Les Mesures Organisationnelles . . . 94
15.2 Le Facteur Humain . . . 94
15.3 La Sensibilisation . . . 94
15.4 Le Cycle de Vie de l'Agent . . . 95
15.5 Fournisseurs et Télétravail . . . 95

16 Mesures Techniques 99

16.1 Le Contrôle d'Accès . . . 100
16.2 L'Authentification Forte . . . 100
16.3 La Sécurité Réseau . . . 100
16.4 Chiffrement et Journalisation . . . 101
16.5 Rattacher aux Critères . . . 101

17 Continuité d'Activité : PCA et PRA 105

17.1 PCA et PRA . . . 106
17.2 L'Analyse d'Impact . . . 106
17.3 Les Indicateurs de Continuité . . . 106
17.4 Sauvegarde et Restauration . . . 106
17.5 La Stratégie de la Mairie . . . 107

VI Contrôler, Auditer, Améliorer 109

18 Surveillance, Mesure et Indicateurs 111

18.1 L'Exigence de Mesure . . . 112
18.2 Performance et Risque . . . 112
18.3 Un Bon Indicateur . . . 112
18.4 Le Tableau de Bord . . . 112
18.5 De la Mesure à la Décision . . . 113

19 L'Audit du SMSI et la Certification 115

19.1 Les Types d'Audit . . . 116
19.2 La Méthodologie . . . 116
19.3 Constat, Preuve, Écart . . . 116
19.4 La Revue de Direction . . . 117
19.5 Le Cycle de Certification . . . 117

20 Gérer les Incidents et Progresser 121

20.1 Le Processus de Gestion . . . 122
20.2 Classer et Prioriser . . . 122

20.3 Le Retour d'Expérience 122
20.4 L'Incident, Moteur d'Amélioration 123
20.5 Mesurer les Progrès 123

A Glossaire **127**

B Référentiel des Outils **129**

C Modèles et Procédures **131**

D Textes Juridiques et Normatifs **133**

E Bibliographie Commentée **135**

F Contacts et Ressources **137**

Références bibliographiques **139**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : LA DÉCISION DE LA MAIRIE

« La sécurité n'est pas un produit que l'on achète,
c'est une décision que l'on tient dans la durée. »

Principe du cours

Niveau : *Introductif* • Aucun prérequis. Les notions sont reprises en détail dans les chapitres.

✦ Objectifs du chapitre

- ➢ Comprendre qu'un incident de sécurité est d'abord un problème de management, non de seule technique.
- ➢ Distinguer la réaction ponctuelle d'une démarche durable et pilotée.
- ➢ Découvrir le fil rouge de la mairie d'Eséka et ses quatre phases.
- ➢ Situer le cycle PDCA au cœur du cours.
- ➢ Formuler les questions auxquelles le cours répond.

13 janvier 2026, 7 h 50, mairie d'Eséka

L'agent d'état civil arrive avant l'ouverture au public. Il branche, comme chaque matin, la clé `USB` sur laquelle il a travaillé la veille chez lui. En quelques minutes, les fichiers du poste deviennent illisibles : les actes de naissance numérisés, le registre des mariages, le tableur des redevances ne s'ouvrent plus. À 8 h 15, trois postes du service sont touchés, reliés au même dossier partagé. À 9 h, une file d'usagers attend des copies d'actes que la mairie ne peut plus délivrer.

Ce que personne ne sait encore ce matin-là[1] : le mal n'est pas la clé `USB`. Le mal, c'est qu'un seul poste suffise à paralyser un service, qu'aucune sauvegarde récente n'existe, que le même mot de passe serve à tout le monde, et que personne, dans la mairie, n'ait jamais décidé qui est responsable de quoi en matière de sécurité.

[1] Cas fictif établi pour le cours. Les noms (mairie d'Eséka, cabinet Matomb Conseil, agents cités), les dates et les montants sont fictifs ; les mécanismes de gestion et les références normatives (ISO/IEC 27001, 27002, 27005, lois camerounaises) sont exacts.

© MaletYon

0.1 Réparer ne suffit pas

Le DSI de la commune, M. Biloa, rétablit les postes en deux jours à partir d'une vieille copie. Le service rouvre. L'affaire pourrait s'arrêter là : on a réparé. Mais le maire, M. Essama, pose la bonne question en conseil : « Qu'est-ce qui nous garantit que cela ne recommencera pas la semaine prochaine, en pire ? »

La réponse est désagréable : rien. Réparer traite l'incident du jour ; cela ne traite pas la **cause**. La cause est organisationnelle : pas de politique, pas de rôles, pas d'appréciation des risques, pas de règles de sauvegarde, pas de contrôle. Tant que ces manques demeurent, le prochain incident est une question de temps. La mairie n'a pas un problème technique : elle a un problème de **management de la sécurité**.

Application RSSI

Du pompier au pilote. Réagir à chaque incident, c'est être pompier. Un RSSI construit un système qui réduit le nombre d'incendies et limite leurs dégâts. Il ne promet pas le risque zéro : il promet un risque *connu*, *décidé* et *maîtrisé*.

0.2 La décision : un système, pas un achat

Le maire ne débloque pas un budget pour « acheter de la sécurité ». Il prend une décision de gouvernance : doter la mairie d'un **système de management de la sécurité de l'information** (SMSI), c'est-à-dire un ensemble de règles, de rôles et d'activités qui, ensemble, maintiennent la sécurité dans la durée. Il nomme Mme Abena RSSI de la commune et mandate le cabinet Matomb Conseil pour l'accompagner vers une certification **[ISO/IEC 27001]**.

Définition

Système de management de la sécurité de l'information (SMSI) : partie du système de management global qui, sur la base d'une appréciation des risques, établit, met en œuvre, exploite, surveille et améliore la sécurité de l'information [10]. Ce n'est pas un logiciel : c'est une manière organisée de décider et de tenir ses décisions.

0.3 Le fil rouge : quatre phases

Le cours suit la mairie d'Eséka, dans le département du Nyong-et-Kéllé, tout au long de sa démarche. Quatre phases, nommées d'après la géographie locale, structurent le fil rouge et reviennent dans les chapitres.

Phase	Ce qu'elle installe
Opération Nyong	La gouvernance et la politique de sécurité (parties I et II)
Opération Kellé	L'appréciation et le traitement des risques (partie IV)
Opération Makak	La mise en œuvre des mesures (partie V)
Opération Matomb	L'audit interne et la certification (partie VI)

Tableau 0.1. Les quatre phases du fil rouge

0.4 Le cœur du cours : le cycle PDCA

Un SMSI n'est pas un projet qui se termine : c'est une **roue** qui tourne. Le cycle PDCA (*Plan, Do, Check, Act*), ou roue de Deming, en est le moteur et revient à chaque partie du cours.

Étape	Ce que fait la mairie
Planifier (*Plan*)	Apprécier les risques, fixer la politique et les objectifs
Déployer (*Do*)	Mettre en œuvre les mesures et former les agents
Contrôler (*Check*)	Mesurer, auditer, passer en revue de direction
Agir (*Act*)	Corriger, améliorer, décider le cycle suivant

Tableau 0.2. Le cycle PDCA appliqué à la mairie

● Note

Les questions auxquelles ce cours répond.

- ➢ Qui décide de la sécurité, et au nom de quoi ?
- ➢ Comment connaître ses risques avant qu'ils ne deviennent des incidents ?
- ➢ Quelles mesures mettre en œuvre, et comment prouver qu'elles fonctionnent ?
- ➢ Comment faire reconnaître, par un audit, que la sécurité est maîtrisée ?

★ À retenir

Ce qu'il faut retenir de ce prologue :

- ➢ Un incident est d'abord un révélateur de **causes organisationnelles**, pas seulement un problème technique.

- **Réparer** traite le symptôme ; **manager** traite la cause.
- Un **SMSI** est un système durable de décisions tenues, non un achat ponctuel.
- Le fil rouge suit la **mairie d'Eséka** en quatre phases.
- Le **cycle PDCA** est le moteur du cours.

Note

Transition. Avant de manager la sécurité, il faut la définir : le Chapitre 1 pose ce qu'est la sécurité de l'information.

partie I

Fondements du Management de la Sécurité

© MaletYon

1

QU'EST-CE QUE LA SÉCURITÉ DE L'INFORMATION

« Protéger l'information, ce n'est pas la cacher :
c'est la rendre sûre, exacte et disponible à qui de droit. »

Principe du cours

Niveau : *Fondamental* • Le prologue. Aucune connaissance technique préalable.

✦ Objectifs du chapitre

- ➢ Définir la sécurité de l'information et la distinguer de la sécurité informatique.
- ➢ Énoncer la triade DIC et l'illustrer sur des actifs réels.
- ➢ Ajouter les critères d'authenticité, de non-répudiation et de traçabilité.
- ➢ Identifier l'information comme un actif à valeur, quel que soit son support.
- ➢ Relier chaque critère à une conséquence concrète pour la mairie.

Question directrice : que protège-t-on, au juste, quand on « sécurise » ?

La clé `USB` a chiffré des fichiers : l'information est devenue indisponible. Mais si elle avait été copiée et revendue, le problème aurait été autre. Ce chapitre nomme précisément ce que l'on protège et selon quels critères.

Plan du chapitre.

1. L'information, un actif (section 1.1).
2. La triade DIC (section 1.2).
3. Les critères complémentaires (section 1.3).
4. Sécurité de l'information ou sécurité informatique (section 1.4).
5. Lire un incident par ses critères (section 1.5).

© *MaletYon*

1.1 L'Information, un Actif

Définition

Information : donnée qui a un sens et une valeur pour l'organisation, quel que soit son support (fichier, papier, parole, savoir d'un agent). **Actif** : tout élément ayant de la valeur et qu'il faut donc protéger.

On sécurise une information parce qu'elle a de la valeur : les actes de naissance font foi, le fichier des contribuables conditionne les recettes, la messagerie engage la commune. La valeur n'est pas dans le disque dur : elle est dans l'information. Protéger le support sans penser l'information, c'est protéger le coffre en oubliant ce qu'il contient.

Actif · Le registre d'état civil numérisé

Constatation. Le registre numérisé des naissances est consultable par tous les agents du service, sans mot de passe individuel, et n'est copié nulle part ailleurs.

Analyse. C'est un actif de valeur majeure (il fait foi) mais sans protection : ni confidentialité (accès non maîtrisé), ni disponibilité (copie unique). Sa valeur et sa vulnérabilité en font une cible prioritaire.

1.2 La Triade DIC

Définition

La **triade DIC** définit trois critères de sécurité :

- **Disponibilité** : l'information est accessible à qui de droit quand il en a besoin.
- **Intégrité** : l'information n'est ni altérée ni détruite de façon non autorisée.
- **Confidentialité** : l'information n'est accessible qu'aux personnes autorisées.

En anglais : *CIA* (Confidentiality, Integrity, Availability).

Les trois critères se tiennent et s'arbitrent. Verrouiller un registre (confidentialité) sans en garder de copie met en péril sa disponibilité. La sécurité consiste à tenir les trois, à hauteur de la valeur de l'actif.

Critère	Atteinte à Eséka	Conséquence
Disponibilité	Registre chiffré, illisible	Service à l'arrêt, usagers bloqués
Intégrité	Date de naissance modifiée	Acte faux, responsabilité engagée
Confidentialité	Fichier contribuables copié	Vie privée exposée, loi 2024/017

Tableau 1.1. La triade DIC sur les actifs de la mairie

1.3 Les Critères Complémentaires

À la triade s'ajoutent, selon les besoins, trois critères :

- **Authenticité** : l'origine de l'information est vérifiée (l'acte vient bien de la mairie).
- **Non-répudiation** : on ne peut nier avoir effectué une action (l'agent qui a validé un acte ne peut le contester).
- **Traçabilité** : les actions sont enregistrées et rattribuables.

Ces critères soutiennent la confiance : un acte authentique, non répudiable et tracé a une valeur juridique qu'un simple fichier n'a pas.

1.4 Sécurité de l'Information ou Sécurité Informatique

Définition

La **sécurité de l'information** protège l'information sous toutes ses formes (numérique, papier, orale). La **sécurité informatique** ne protège que les systèmes qui la traitent. La première englobe la seconde.

La distinction n'est pas scolaire. À la mairie, un acte lu à voix haute au guichet, un dossier papier oublié sur un bureau ou une confidence échappent à toute mesure informatique mais relèvent de la sécurité de l'information. Un SMSI couvre l'information, pas seulement les ordinateurs.

Application RSSI

Penser actif, pas machine. Le RSSI d'Eséka commence par lister les informations de valeur et leur support, avant de parler pare-feu. On protège ce qui a de la valeur, pas ce qui a une prise électrique.

1.5 Lire un Incident par ses Critères

Nommer les critères donne une grille de lecture. Tout incident s'analyse en demandant quel critère a été atteint, sur quel actif, et avec quelle conséquence.

Mesure

Constatation. Le 13 janvier, les fichiers du service d'état civil sont illisibles.

Analyse (confiance élevée). Critère atteint : *disponibilité*. Actif : registres et tableurs du service. L'intégrité et la confidentialité ne sont pas, à ce stade, mises en cause : distinguer les trois évite de conclure trop vite à un vol de données.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- L'**information** est un actif à valeur ; on la protège pour cette valeur.
- La **triade DIC** (disponibilité, intégrité, confidentialité) définit ce que « sécuriser » veut dire.
- **Authenticité, non-répudiation, traçabilité** soutiennent la confiance.
- La **sécurité de l'information** dépasse la sécurité informatique.
- Tout incident se lit par le **critère atteint** sur un actif.

● Note

Points de contrôle de l'élève. Je sais : définir information et actif ; énoncer la triade DIC ; citer les trois critères complémentaires ; distinguer sécurité de l'information et sécurité informatique ; analyser un incident par ses critères.

✍ **Exercice 1.1. Trois critères** ★☆☆

Pour chacun des cas suivants, dites quel critère DIC est atteint : registre chiffré ; montant d'une taxe modifié ; liste d'électeurs copiée.

✍ **Exercice 1.2. Actif ou support** ★☆☆

Parmi : le disque dur, l'acte de naissance, l'ordinateur, le savoir de l'agent, lesquels sont des actifs informationnels ? Justifiez.

✍ **Exercice 1.3. Information ou informatique** ★☆☆

Donnez un exemple, à la mairie, d'atteinte à la sécurité de l'information qui ne passe par aucun ordinateur.

✍ **Exercice 1.4. Les compléments** ★★☆

Expliquez, sur l'exemple d'un acte de naissance, l'authenticité, la non-répudiation et la traçabilité.

✍ **Exercice 1.5. Arbitrage** ★★☆

Verrouiller le registre sans copie renforce un critère et en menace un autre. Lesquels ? Comment tenir les deux ?

✍ **Exercice 1.6. Valeur d'un actif** ★★☆

Classez trois actifs de la mairie par valeur décroissante et justifiez le classement.

✍ Exercice 1.7. Grille de lecture ★★☆

Appliquez la grille « critère / actif / conséquence » au vol du fichier des contribuables.

✍ Exercice 1.8. Confidentialité et loi ★★☆

En quoi une atteinte à la confidentialité du fichier des contribuables engage-t-elle la mairie au regard de la loi 2024/017 ?

✍ Exercice 1.9. Cartographie ★★★

Dressez un tableau des cinq principaux actifs informationnels de la mairie d'Eséka, avec leur support et les critères prioritaires pour chacun.

✍ Exercice 1.10. Note de cadrage ★★★

Rédigez une note d'une page au maire définissant « sécurité de l'information » pour la mairie et justifiant pourquoi elle dépasse l'achat d'un antivirus.

● Note

Pour aller plus loin.

➢ ISO/IEC 27000 [9] ; ISO/IEC 27001 [10].

● Note

Transition. Savoir ce que l'on protège ne dit pas encore pourquoi ni pour qui : le Chapitre 2 relie le risque à la décision.

2

DU RISQUE À LA DÉCISION

« Sécuriser, c'est décider : quel risque accepter, lequel réduire, et avec quelles ressources. »

Principe du cours

Niveau : *Fondamental* • Le Chapitre 1.

✦ Objectifs du chapitre

- ➢ Relier la sécurité aux enjeux économiques, réglementaires et stratégiques de l'organisation.
- ➢ Identifier les acteurs de la sécurité et leurs responsabilités.
- ➢ Définir le patrimoine informationnel à protéger.
- ➢ Comprendre que la sécurité est une décision fondée sur le risque.
- ➢ Situer la mairie d'Eséka dans son écosystème (ANTIC, parties prenantes).

Question directrice : au nom de quoi la mairie investit-elle dans la sécurité ?

Dépenser pour la sécurité, c'est renoncer à dépenser ailleurs. Ce chapitre montre que cette dépense se justifie par des enjeux, s'organise autour d'acteurs et se décide en fonction du risque.

Plan du chapitre.

1. Les enjeux (section 2.1).
2. Les acteurs (section 2.2).
3. Le patrimoine informationnel (section 2.3).
4. La sécurité, une décision (section 2.4).
5. L'écosystème de la mairie (section 2.5).

© *MaletYon*

2.1 Les Enjeux

Enjeu	Pour la mairie d'Eséka
Économique	Service interrompu, recettes de taxes retardées, remédiation coûteuse
Réglementaire	Loi 2024/017 sur les données personnelles, obligations de l'ANTIC
Stratégique	Confiance des usagers, image de la commune, continuité du service public

Tableau 2.1. Les enjeux de la sécurité pour la mairie

Pour une collectivité, l'enjeu premier n'est pas le chiffre d'affaires mais la **continuité du service public** et la confiance des administrés. Un état civil à l'arrêt, c'est un citoyen qui ne peut ni se marier, ni inscrire un enfant, ni prouver son identité.

2.2 Les Acteurs

Acteur	Responsabilité
Le maire (direction)	Impulse, valide la politique, alloue les ressources, assume
RSSI	Pilote la sécurité, apprécie les risques, propose les mesures
DSI	Met en œuvre les solutions techniques
DPO / conseil	Veille à la conformité des traitements de données personnelles
Agents (utilisateurs)	Respectent les règles, signalent les incidents
ANTIC	Autorité nationale : appui, contrôle, réponse aux incidents

Tableau 2.2. Les acteurs et leurs responsabilités

La sécurité n'est l'affaire de personne si elle est l'affaire de tous sans responsabilité nommée. La première décision du maire, nommer une RSSI, crée le point où la responsabilité se concentre.

Application Direction générale

Le rôle que nul ne peut déléguer. Le maire peut déléguer la mise en œuvre, jamais la responsabilité finale. C'est lui qui arbitre entre le risque et le coût, parce que lui seul engage la commune.

2.3 Le Patrimoine Informationnel

Définition

Patrimoine informationnel : ensemble des informations de valeur d'une organisation et des moyens qui les portent. Le protéger suppose d'abord de le connaître.

Actif · Le patrimoine de la mairie

Constatation. Avant la démarche, la mairie n'a aucun inventaire de ses informations sensibles.

Analyse. On ne protège bien que ce que l'on a recensé. L'opération NYONG commencera par un inventaire : état civil, fichier des contribuables, délibérations du conseil, messagerie, site web. Sans cet inventaire, l'appréciation des risques n'a pas d'objet.

2.4 La Sécurité, une Décision

La sécurité absolue n'existe pas et coûterait trop cher. Sécuriser, c'est donc **décider** : pour chaque risque, choisir de le réduire, de le transférer, de l'éviter ou de l'accepter (Chapitre 13). Cette décision appartient à la direction, sur proposition du RSSI et au vu des risques appréciés.

Note

Le fondement du SMSI. Tout le cours découle de cette idée : la sécurité se *décide* sur la base du *risque*. C'est pourquoi l'appréciation des risques (partie IV) est le cœur de la norme [ISO/IEC 27001].

2.5 L'Écosystème de la Mairie

La mairie n'est pas seule. Elle dépend de prestataires (hébergeur du site, éditeur du logiciel d'état civil), relève d'autorités (ANTIC, tutelle) et sert des usagers. Ces **parties intéressées** ont des attentes de sécurité qui s'imposent au SMSI et seront recensées à la clause 4 de la norme (Chapitre 8).

Jurisprudence & Droit applicable

La loi camerounaise n° 2024/017 du 23 décembre 2024 sur la protection des données à caractère personnel impose au responsable de traitement (ici, la mairie) de garantir la sécurité des données qu'il détient. La sécurité n'est donc pas seulement prudente : elle est une obligation légale.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La sécurité répond à des **enjeux** économiques, réglementaires et stratégiques ; pour une mairie, la continuité du service public prime.
- Chaque **acteur** a une responsabilité nommée ; la direction assume, le RSSI pilote.
- On protège un **patrimoine informationnel** qu'il faut d'abord inventorier.
- Sécuriser est une **décision** fondée sur le risque.
- Les **parties intéressées** imposent des attentes au SMSI.

● Note

Points de contrôle de l'élève. Je sais : citer les trois types d'enjeux ; nommer les acteurs et leurs rôles ; définir le patrimoine informationnel ; expliquer pourquoi la sécurité est une décision ; citer une obligation légale.

✍ **Exercice 2.1. Trois enjeux** ★☆☆

Donnez, pour la mairie, un exemple concret d'enjeu économique, réglementaire et stratégique.

✍ **Exercice 2.2. Qui fait quoi** ★☆☆

Reliez chaque acteur (maire, RSSI, DSI, agent) à sa responsabilité principale.

✍ **Exercice 2.3. Inventaire** ★☆☆

Listez cinq informations de valeur que détient une mairie.

✍ **Exercice 2.4. Responsabilité finale** ★★☆

Pourquoi le maire ne peut-il pas déléguer la responsabilité finale de la sécurité ?

✍ **Exercice 2.5. Décider** ★★☆

« La mairie n'a qu'à tout sécuriser au maximum. » Montrez les limites de cette phrase.

✍ **Exercice 2.6. Parties intéressées** ★★☆

Identifiez quatre parties intéressées de la mairie et une attente de sécurité pour chacune.

✍ Exercice 2.7. Continuité publique ★★☆

Pourquoi la continuité du service public pèse-t-elle plus, pour une mairie, que pour une entreprise commerciale ?

✍ Exercice 2.8. Obligation légale ★★☆

En quoi la loi 2024/017 transforme-t-elle la sécurité des données de la mairie en obligation ?

✍ Exercice 2.9. Cartographie des acteurs ★★★

Dressez l'organigramme de sécurité que la mairie d'Eséka devrait adopter, avec les responsabilités de chacun.

✍ Exercice 2.10. Argumentaire budgétaire ★★★

Rédigez l'argumentaire par lequel la RSSI justifie, devant le conseil, un budget sécurité, en s'appuyant sur les enjeux et le risque.

Note

Pour aller plus loin.

➢ ISO/IEC 27001 [10] ; ISO 31000 [5].

Note

Transition. Décider une fois ne suffit pas : il faut un cycle qui entretienne la décision. Le Chapitre 3 présente le PDCA.

3

LE CYCLE PDCA ET L'AMÉLIORATION CONTINUE

« Un système de sécurité qui ne tourne pas se dégrade :
ce qui était sûr hier ne l'est plus demain. »

Principe du cours

Niveau : *Fondamental* • Les Chapitres 1 et 2.

✦ Objectifs du chapitre

- ➢ Énoncer les quatre étapes du cycle PDCA.
- ➢ Comprendre pourquoi la sécurité est un cycle et non un projet.
- ➢ Relier chaque étape aux parties du cours et aux phases du fil rouge.
- ➢ Distinguer correction, action corrective et amélioration.
- ➢ Situer l'amélioration continue comme exigence de la norme.

Question directrice : pourquoi la sécurité n'est-elle jamais « finie » ?

La mairie pourrait croire qu'après avoir installé des mesures, le travail est accompli. Ce chapitre montre que la sécurité se dégrade si on ne l'entretient pas, et que le cycle PDCA est l'outil de cet entretien.

Plan du chapitre.

1. Les quatre étapes (section 3.1).
2. Un cycle, pas un projet (section 3.2).
3. PDCA et plan du cours (section 3.3).
4. Corriger, améliorer (section 3.4).
5. L'amélioration continue, une exigence (section 3.5).

© MaletYon

3.1 Les Quatre Étapes

Définition

Le **cycle PDCA** (*Plan, Do, Check, Act*), ou roue de Deming, organise l'amélioration continue en quatre étapes répétées : **planifier**, **déployer**, **contrôler**, **agir**.

Étape	But	À la mairie
Planifier	Fixer objectifs et mesures	Apprécier les risques, écrire la politique
Déployer	Mettre en œuvre	Déployer les mesures, former les agents
Contrôler	Vérifier l'efficacité	Mesurer, auditer, revue de direction
Agir	Améliorer	Corriger les écarts, décider le cycle suivant

Tableau 3.1. Le cycle PDCA, étape par étape

3.2 Un Cycle, pas un Projet

Un projet a une fin ; un cycle recommence. La menace évolue, les agents changent, les systèmes vieillissent : une mesure efficace en janvier peut ne plus l'être en décembre. Le PDCA rattrape cette dérive en imposant de revenir régulièrement sur ce qui a été décidé.

Scénario Opérationnel · Opération NYONG. Le piège du « c'est fait »

Constatation. Six mois après avoir imposé des mots de passe individuels, la mairie découvre que trois agents les ont de nouveau partagés.

Analyse (confiance élevée). La mesure avait été déployée (*Do*) mais jamais contrôlée (*Check*). Sans l'étape de contrôle, une mesure se relâche. Le cycle n'est pas une formalité : c'est ce qui empêche le retour en arrière.

3.3 PDCA et Plan du Cours

Le cours épouse le cycle. Les parties II et III *planifient* (gouvernance, politique, cadre [ISO/IEC 27001]) ; la partie IV *planifie* par le risque ; la partie V *déploie* les mesures ; la partie VI *contrôle* et *agit* (audit, certification, incidents, amélioration).

Application RSSI

Tenir la roue. Le RSSI n'a pas pour mission de « finir » la sécurité, mais de faire tourner la roue : chaque année, replanifier au vu des nouveaux risques et des écarts constatés. Son tableau de bord suit le cycle.

3.4 Corriger, Améliorer

Définition

Correction : action immédiate qui traite un écart constaté (rétablir un service). **Action corrective** : action qui traite la *cause* de l'écart pour qu'il ne se reproduise pas. **Amélioration** : renforcement au-delà de la simple conformité.

Rétablir les postes après la clé `USB` était une *correction*. Interdire les clés personnelles et imposer des sauvegardes est une *action corrective*. Automatiser la détection des clés non autorisées serait une *amélioration*. La norme attend les trois, dans cet ordre de maturité.

3.5 L'Amélioration Continue, une Exigence

L'amélioration continue n'est pas une bonne intention : c'est la clause 10 de la norme [ISO/IEC 27001] (Chapitre 9). Un SMSI qui ne s'améliore pas n'est pas conforme. Le PDCA est donc à la fois une philosophie et une exigence vérifiée en audit.

Note

À retenir pour tout le cours. Chaque fois qu'une partie s'ouvre, demandez-vous à quelle étape du PDCA elle correspond. La structure du cours *est* le cycle.

À retenir

Ce qu'il faut retenir de ce chapitre :

- Le **PDCA** (planifier, déployer, contrôler, agir) organise l'amélioration continue.
- La sécurité est un **cycle**, pas un projet : sans entretien, elle se dégrade.
- Le **cours** suit les étapes du cycle.
- **Correction**, **action corrective** et **amélioration** se distinguent par ce qu'elles traitent.
- L'**amélioration continue** est une exigence de la norme (clause 10).

Note

Points de contrôle de l'élève. Je sais : énoncer les quatre étapes ; expliquer pourquoi la sécurité est un cycle ; relier le PDCA au plan du cours ; distinguer correction, action corrective et amélioration ; rattacher l'amélioration continue à la norme.

✍ Exercice 3.1. Les quatre étapes ★☆☆

Nommez les quatre étapes du PDCA et donnez une action de la mairie pour chacune.

✍ Exercice 3.2. Cycle ou projet ★☆☆

Expliquez en deux phrases pourquoi la sécurité n'est pas un projet qui se termine.

✍ Exercice 3.3. Trois mots ★☆☆

Distinguez correction, action corrective et amélioration par un exemple de chacune.

✍ Exercice 3.4. L'étape manquante ★★☆

Dans le cas des mots de passe repartagés, quelle étape du cycle a manqué ? Justifiez.

✍ Exercice 3.5. Rattacher au cycle ★★☆

À quelle étape du PDCA rattachez-vous : un audit interne ; une formation ; une appréciation des risques ; une revue de direction ?

✍ Exercice 3.6. De la correction à la cause ★★☆

Pour l'incident de la clé `USB`, proposez une correction, une action corrective et une amélioration.

✍ Exercice 3.7. Dérive ★★☆

Donnez deux raisons pour lesquelles une mesure efficace peut cesser de l'être avec le temps.

✍ Exercice 3.8. Exigence ★★☆

Pourquoi un SMSI qui ne s'améliore jamais n'est-il pas conforme à **[ISO/IEC 27001]** ?

✍ Exercice 3.9. Planifier un tour ★★★

Décrivez un cycle PDCA annuel complet pour la mairie d'Eséka, de la planification à l'amélioration.

✍ Exercice 3.10. Note au conseil ★★★

Rédigez une note expliquant au conseil municipal pourquoi la sécurité nécessite un budget récurrent, et non une dépense unique.

Note

Pour aller plus loin.

➢ ISO/IEC 27001, approche processus et clause 10 [10].

Note

Transition. Faire tourner la roue suppose une organisation qui la porte : le Chapitre 4 ouvre la gouvernance de la sécurité.

partie II

Gouvernance et Politique de Sécurité

© MaletYon

4

LA GOUVERNANCE DE LA SÉCURITÉ

« Sans responsable nommé, la sécurité est l'affaire de personne. »

Principe du cours

Niveau : *Fondamental* • La partie I.

✦ Objectifs du chapitre

- ➢ Définir la gouvernance de la sécurité et la distinguer du management opérationnel.
- ➢ Préciser le rôle du RSSI, de la direction et du comité de sécurité.
- ➢ Comprendre le rattachement et l'indépendance du RSSI.
- ➢ Établir une matrice de responsabilités (RACI).
- ➢ Relier la gouvernance à l'engagement de la direction exigé par la norme.

Question directrice : qui décide, qui exécute, qui contrôle ?

Nommer une RSSI ne suffit pas : encore faut-il définir ses pouvoirs, son rattachement et ses relations avec la direction et les services. Ce chapitre organise la gouvernance de la sécurité à la mairie.

Plan du chapitre.

1. Gouverner et manager (section 4.1).
2. Le RSSI (section 4.2).
3. La direction et le comité de sécurité (section 4.3).
4. La matrice de responsabilités (section 4.4).
5. L'engagement de la direction (section 4.5).

❍

4.1 Gouverner et Manager

Définition

Gouvernance de la sécurité : ensemble des responsabilités et pratiques par lesquelles la direction oriente la sécurité, fixe les objectifs et s'assure que les risques sont maîtrisés. Elle décide ; le management exécute.

La gouvernance répond à « quoi et pourquoi » ; le management opérationnel à « comment ». Confondre les deux conduit soit à une direction qui bricole de la technique, soit à une technique sans mandat. La norme sépare nettement le rôle d'orientation (direction) du rôle de pilotage (RSSI).

4.2 Le RSSI

Mission	Contenu
Définir	Proposer la stratégie et la politique de sécurité
Piloter	Conduire l'appréciation des risques et le plan de traitement
Coordonner	Mettre en relation direction, DSI, agents, prestataires
Contrôler	Vérifier le respect des règles, suivre les indicateurs
Conseiller	Éclairer la direction pour ses arbitrages

Tableau 4.1. Les missions du RSSI

Mesure

Constatation. À la mairie, Mme Abena (RSSI) est aussi chef du service informatique, sous l'autorité du DSI.

Analyse (confiance moyenne). Ce rattachement crée un conflit : juger la sécurité des systèmes que l'on exploite soi-même, c'est être juge et partie. Il est préférable que la RSSI rende compte directement au maire, pour garder son indépendance de contrôle.

4.3 La Direction et le Comité de Sécurité

La direction (le maire) impulse, valide la politique, alloue les ressources et assume la responsabilité finale. Pour instruire ses décisions, elle s'appuie sur un **comité de sécurité** : instance périodique qui réunit maire, RSSI, DSI et responsables de services, arbitre les risques et suit le plan d'action.

Application Direction générale

Présider, pas assister. Un comité de sécurité que le maire délègue systématiquement perd son autorité. La présence de la direction signale que la sécurité est une priorité, non une affaire de techniciens.

4.4 La Matrice de Responsabilités

Définition

Une matrice **RACI** attribue, pour chaque activité, qui est *Responsable* (fait), *Approbateur* (décide), *Consulté* et *Informé*. Elle supprime les zones où « on croyait que l'autre le faisait ».

Activité	Maire	RSSI	DSI
Valider la politique	A	R	C
Apprécier les risques	I	R	C
Déployer une mesure	I	A	R
Suivre les indicateurs	I	R	C

Tableau 4.2. Extrait de la matrice RACI de la mairie

4.5 L'Engagement de la Direction

La gouvernance n'existe que si la direction s'engage réellement. La clause 5 de [ISO/IEC 27001] l'exige : la direction doit démontrer son **leadership** en établissant la politique, en attribuant les rôles et en fournissant les ressources (Chapitre 8).

Jurisprudence & Droit applicable

En droit camerounais comme dans la norme, la responsabilité de la sécurité des données remonte au responsable de traitement. Le maire ne peut se retrancher derrière ses services : la gouvernance formalise cette responsabilité, elle ne la dilue pas.

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **gouvernance** oriente et décide ; le management exécute.
- Le **RSSI** définit, pilote, coordonne, contrôle, conseille ; son indépendance suppose un bon rattachement.
- La **direction** impulse et assume ; le **comité de sécurité** instruit ses décisions.
- La **matrice RACI** supprime les responsabilités floues.
- La norme exige l'**engagement** de la direction (clause 5).

Note

Points de contrôle de l'élève. Je sais : distinguer gouverner et manager ; énoncer les missions du RSSI ; expliquer le rôle du comité ; lire une matrice RACI ; relier la gouvernance à la clause 5.

✍ Exercice 4.1. Gouverner ou manager ★☆☆

Classez : fixer la politique ; configurer un pare-feu ; arbitrer un budget ; appliquer un correctif. Gouvernance ou management ?

✍ Exercice 4.2. Missions du RSSI ★☆☆

Citez cinq missions du RSSI et donnez un exemple pour l'une d'elles.

✍ Exercice 4.3. Le comité ★☆☆

Qui siège au comité de sécurité de la mairie, et à quoi sert-il ?

✍ Exercice 4.4. Juge et partie ★★☆

Pourquoi rattacher la RSSI au DSI pose-t-il un problème d'indépendance ? Proposez un meilleur rattachement.

✍ Exercice 4.5. RACI ★★☆

Complétez une ligne RACI pour l'activité « gérer les accès des agents ».

✍ Exercice 4.6. Leadership ★★☆

Donnez trois actes concrets par lesquels le maire démontre son engagement.

✍ Exercice 4.7. Délégation ★★☆

Que peut déléguer le maire, que ne peut-il pas déléguer ? Justifiez.

✍ Exercice 4.8. Zone floue ★★☆

Donnez un exemple de responsabilité floue à la mairie et montrez comment la RACI la lève.

✍ Exercice 4.9. Charte de comité ★★★

Rédigez la charte du comité de sécurité de la mairie (composition, fréquence, missions, décisions).

✍ Exercice 4.10. Fiche de poste ★★★

Rédigez la fiche de poste de la RSSI de la mairie d'Eséka, avec rattachement et pouvoirs.

● Note

Pour aller plus loin.

➢ ISO/IEC 27001, clause 5 [10] ; COBIT 2019 [3].

● Note

Transition. La gouvernance s'exprime d'abord dans un document : le Chapitre 5 construit la politique de sécurité.

5

LA POLITIQUE DE SÉCURITÉ DU SYSTÈME D'INFORMATION

« Une politique qui ne s'applique pas est pire que pas de politique : elle donne l'illusion d'être protégé. »

Principe du cours

Niveau : *Fondamental* • Le Chapitre 4.

✦ Objectifs du chapitre

- ➢ Définir la politique de sécurité (PSSI) et ses objectifs.
- ➢ Décrire la structure type d'une politique de sécurité.
- ➢ Distinguer politique, procédure et charte.
- ➢ Comprendre le cycle de vie d'une politique (validation, diffusion, révision).
- ➢ Relier la politique à l'exigence de la clause 5.2 de la norme.

Question directrice : comment transformer des intentions en règles opposables ?

Le maire veut « plus de sécurité ». Cette intention ne protège rien tant qu'elle n'est pas écrite, validée, diffusée et appliquée. La politique de sécurité est le document qui opère cette transformation.

Plan du chapitre.

1. Qu'est-ce qu'une politique (section 5.1).
2. Objectifs et portée (section 5.2).
3. La structure type (section 5.3).
4. Politique, procédure, charte (section 5.4).
5. Le cycle de vie du document (section 5.5).

© *MaletYon*

5.1 Qu'est-ce qu'une Politique

Définition

Politique de sécurité du système d'information (PSSI) : document formel, approuvé par la direction, qui fixe les objectifs de sécurité, les règles à respecter et les responsabilités. Elle est le cadre de référence de toutes les décisions de sécurité.

La PSSI est au SMSI ce que la constitution est à un État : le texte fondateur dont découlent les règles particulières. Elle doit être courte, claire, et tenue par la direction, sans quoi elle reste lettre morte.

5.2 Objectifs et Portée

Objectif	Ce qu'il apporte
Établir un cadre	Une référence commune pour arbitrer
Sensibiliser	Des règles connues de tous les agents
Définir les responsabilités	Chacun sait ce qu'il doit faire
Assurer la conformité	Le respect des obligations légales
Faciliter la décision	Un critère pour trancher les cas particuliers

Tableau 5.1. Les objectifs d'une politique de sécurité

La **portée** délimite ce que couvre la politique : quels services, quels sites, quelles informations. À Eséka, la politique couvre tous les services de la mairie et l'ensemble du patrimoine informationnel recensé.

5.3 La Structure Type

Section	Contenu
Introduction et contexte	Objectifs, portée, références réglementaires
Gouvernance	Organisation, rôles, comité de sécurité
Classification de l'information	Niveaux et règles de manipulation
Contrôle d'accès	Création des comptes, authentification, privilèges
Sécurité des opérations	Sauvegarde, journalisation, gestion des incidents
Conformité	Audits, revue, sanctions

Tableau 5.2. Structure type d'une politique de sécurité

Application RSSI

Écrire pour être lu. La RSSI d'Eséka proscrit le jargon : une politique que les agents ne comprennent pas n'est pas appliquée. Chaque règle dit qui, quoi, quand, et la conséquence du non-respect.

5.4 Politique, Procédure, Charte

Définition

Trois niveaux se complètent : la **politique** fixe les principes (le « quoi ») ; la **procédure** décrit les étapes d'exécution (le « comment ») ; la **charte** engage l'utilisateur sur ses droits et devoirs.

La politique dit « les accès sont nominatifs » ; la procédure décrit comment créer et supprimer un compte ; la charte informatique, signée par l'agent, l'engage à ne pas partager son mot de passe (Chapitre 6).

5.5 Le Cycle de Vie du Document

Une politique vit : elle est **rédigée**, **validée** par la direction, **diffusée** à tous, **appliquée**, puis **révisée** périodiquement. Sans validation de la direction, elle n'a pas d'autorité ; sans révision, elle se périme.

Mesure

Constatation. La mairie a rédigé une politique en 2022, jamais signée par le maire ni communiquée aux agents.

Analyse (confiance élevée). Un document non validé et non diffusé n'est pas une politique : c'est un brouillon. L'opération NYONG reprendra le cycle complet, de la validation à la diffusion contre signature.

Jurisprudence & Droit applicable

La clause 5.2 de [ISO/IEC 27001] exige une politique de sécurité établie, approuvée par la direction, communiquée et disponible. L'absence de politique formelle est un écart majeur en audit de certification (Chapitre 19).

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **PSSI** est le texte fondateur du SMSI, approuvé par la direction.
- Elle poursuit cinq **objectifs** et définit une **portée**.

- ➢ Sa **structure type** couvre gouvernance, accès, opérations, conformité.
- ➢ **Politique, procédure, charte** se distinguent par leur niveau.
- ➢ Une politique a un **cycle de vie** : validée, diffusée, révisée ; la clause 5.2 l'exige.

Note

Points de contrôle de l'élève. Je sais : définir la PSSI ; citer ses objectifs ; décrire sa structure ; distinguer politique, procédure et charte ; énoncer son cycle de vie.

✍ Exercice 5.1. Définition ★☆☆

Qu'est-ce qu'une politique de sécurité, et qui doit l'approuver ?

✍ Exercice 5.2. Objectifs ★☆☆

Citez trois objectifs d'une PSSI et illustrez-en un pour la mairie.

✍ Exercice 5.3. Trois niveaux ★☆☆

Classez : « les accès sont nominatifs » ; « voici comment créer un compte » ; « je m'engage à ne pas partager mon mot de passe ». Politique, procédure ou charte ?

✍ Exercice 5.4. Portée ★★☆

Rédigez la phrase de portée de la politique de la mairie d'Eséka.

✍ Exercice 5.5. Brouillon ou politique ★★☆

Pourquoi le document de 2022 n'est-il pas une politique ? Que manque-t-il ?

✍ Exercice 5.6. Une règle complète ★★☆

Rédigez une règle de politique sur l'usage des clés `USB`, avec la conséquence du non-respect.

✍ Exercice 5.7. Cycle de vie ★★☆

Énoncez les cinq étapes du cycle de vie d'une politique et le risque d'en oublier une.

✍ Exercice 5.8. Écart d'audit ★★☆

Pourquoi l'absence de politique validée est-elle un écart majeur en audit ?

✍ Exercice 5.9. Table des matières ★★★

Dressez la table des matières complète de la politique de sécurité de la mairie d'Eséka.

✍ **Exercice 5.10. Section rédigée** ★★★

Rédigez la section « Contrôle d'accès » de la politique de la mairie (une page).

● **Note**

Pour aller plus loin.

➢ ISO/IEC 27001, clause 5.2 [10] ; ISO/IEC 27002 [11].

● **Note**

Transition. La politique s'adosse à des obligations légales et à des engagements individuels : le Chapitre 6 traite chartes, conformité et données personnelles.

6

CHARTES, CONFORMITÉ ET PROTECTION DES DONNÉES

« Les données personnelles ne sont pas la propriété de la mairie : elles lui sont confiées. »

Principe du cours

Niveau : *Fondamental* • Le Chapitre 5.

✦ Objectifs du chapitre

- ➢ Rédiger et faire vivre une charte informatique.
- ➢ Énoncer les principes de protection des données personnelles.
- ➢ Situer la loi camerounaise 2024/017 et la Convention de Malabo.
- ➢ Définir le rôle du délégué à la protection des données (DPO).
- ➢ Distinguer sécurité et conformité, et montrer leur recouvrement.

Question directrice : la mairie a-t-elle le droit de faire ce qu'elle fait de ses données ?

La mairie détient des données très sensibles : naissances, mariages, décès, contribuables. En détenir ne vaut pas en faire ce que l'on veut. Ce chapitre pose le cadre de conformité et l'engagement des agents.

Plan du chapitre.

1. La charte informatique (section 6.1).
2. Les principes de protection des données (section 6.2).
3. Le cadre juridique camerounais (section 6.3).
4. Le délégué à la protection des données (section 6.4).
5. Sécurité et conformité (section 6.5).

© MaletYon

6.1 La Charte Informatique

Définition

Charte informatique : document opérationnel qui précise les règles d'utilisation du système d'information, les droits et devoirs des utilisateurs, et les sanctions en cas de non-respect. Signée, elle engage l'agent.

La charte traduit la politique en obligations individuelles : usage des postes, gestion des mots de passe, messagerie, supports amovibles, télétravail. Sa force vient de la signature : un agent qui a signé ne peut plaider l'ignorance.

6.2 Les Principes de Protection des Données

Principe	Exigence
Licéité et loyauté	Une base légale pour chaque traitement
Finalité	Données collectées pour un but déterminé
Minimisation	Données pertinentes et limitées au nécessaire
Exactitude	Données exactes et tenues à jour
Conservation limitée	Durée de conservation appropriée
Sécurité	Mesures techniques et organisationnelles
Responsabilité	Démontrer la conformité

Tableau 6.1. Les principes de protection des données

Actif · Le fichier des contribuables

Constatation. Le fichier des contribuables contient des informations qui ne servent plus (anciens redevables partis depuis dix ans).

Analyse. Deux principes sont en défaut : la *minimisation* et la *conservation limitée*. Conserver sans fin expose inutilement des données personnelles. La conformité impose une politique de purge.

6.3 Le Cadre Juridique Camerounais

Jurisprudence & Droit applicable

La loi camerounaise n° 2024/017 du 23 décembre 2024 régit la protection des données à caractère personnel : elle impose une base légale, la sécurité des données et des droits aux personnes concernées. La Convention de l'Union africaine sur la cybersécurité et la protection des données (Convention de **Malabo**, 2014) fixe le cadre continental. La mairie, responsable de traitement, doit s'y conformer.

La conformité n'est pas optionnelle pour une administration : elle conditionne la légalité même du service rendu.

6.4 Le Délégué à la Protection des Données

Définition

Délégué à la protection des données (DPO) : personne chargée de veiller à la conformité des traitements de données personnelles, de conseiller l'organisation et de faire le lien avec l'autorité de protection.

À Eséka, faute de DPO interne, la mairie confie ce rôle à Me Essomba, conseil extérieur. Le DPO tient le registre des traitements, évalue les risques pour la vie privée et instruit les demandes des usagers.

Application Responsable conformité

Conformité n'est pas sécurité. Le responsable conformité vérifie que la mairie respecte ses obligations ; le RSSI réduit les risques. Les deux se recoupent mais ne se confondent pas : on peut être sécurisé et non conforme (données gardées trop longtemps), ou conforme sur le papier et peu sécurisé.

6.5 Sécurité et Conformité

La sécurité (DIC) et la conformité (respect des règles) se recouvrent largement : la loi exige la sécurité, et la sécurité sert la conformité. Mais elles diffèrent de logique : la sécurité part du *risque*, la conformité part de l'*obligation*. Un bon SMSI tient les deux.

Note

Un pont vers le reste du cours. La conformité donne des exigences d'entrée à l'appréciation des risques (partie IV) : certaines mesures seront obligatoires quel que soit le niveau de risque, parce que la loi les impose.

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **charte informatique** engage l'agent par sa signature.
- Les **principes** de protection des données (finalité, minimisation, conservation limitée…) encadrent les traitements.
- La **loi 2024/017** et la **Convention de Malabo** fixent le cadre camerounais et africain.
- Le **DPO** veille à la conformité des traitements.
- **Sécurité et conformité** se recoupent sans se confondre.

Note

Points de contrôle de l'élève. Je sais : rédiger une règle de charte ; citer les principes de protection des données ; situer la loi 2024/017 et Malabo ; définir le rôle du DPO ; distinguer sécurité et conformité.

✍ Exercice 6.1. La charte ★☆☆

Citez trois règles que doit contenir la charte informatique de la mairie.

✍ Exercice 6.2. Les principes ★☆☆

Énoncez quatre principes de protection des données personnelles.

✍ Exercice 6.3. La loi ★☆☆

Quelle loi camerounaise régit la protection des données personnelles, et de quand date-t-elle ?

✍ Exercice 6.4. Deux principes en défaut ★★☆

Pour le fichier des contribuables conservé sans fin, quels principes sont violés ? Que faire ?

✍ Exercice 6.5. Rôle du DPO ★★☆

Décrivez trois missions du DPO à la mairie d'Eséka.

✍ Exercice 6.6. Sécurisé mais non conforme ★★☆

Donnez un exemple d'une mairie bien sécurisée mais non conforme à la loi.

✍ Exercice 6.7. Base légale ★★☆

Quelle base légale justifie que la mairie traite les actes d'état civil ?

✍ Exercice 6.8. Signature ★★☆

Pourquoi la signature de la charte est-elle juridiquement importante ?

✍ Exercice 6.9. Charte rédigée ★★★

Rédigez une charte informatique d'une page pour les agents de la mairie d'Eséka.

✍ Exercice 6.10. Registre des traitements ★★★

Dressez un extrait du registre des traitements de la mairie (trois traitements, finalité, données, durée de conservation).

Note

Pour aller plus loin.

➢ Loi 2024/017 [14] ; Convention de Malabo [17].

Note

Transition. Gouvernance, politique et conformité posées, le cours entre dans la norme qui les structure : le Chapitre 7 présente la famille **[ISO/IEC 27000]**.

partie III

Le SMSI selon ISO/IEC 27001

© MaletYon

7

LA FAMILLE ISO/IEC 27000 ET LE SMSI

« Une norme ne protège rien par elle-même :
elle organise la manière dont on se protège. »

Principe du cours

Niveau : *Fondamental* • La partie II.

✦ Objectifs du chapitre

- ➢ Situer la famille [ISO/IEC 27000] et ses principales normes.
- ➢ Distinguer la norme d'exigences (27001) des normes de lignes directrices.
- ➢ Comprendre ce qu'est un SMSI au sens de la norme.
- ➢ Expliquer le principe de la certification.
- ➢ Replacer la démarche de la mairie dans ce cadre.

Question directrice : pourquoi s'appuyer sur une norme plutôt que bricoler ?

La mairie pourrait inventer sa propre méthode. S'appuyer sur [ISO/IEC 27001], c'est hériter d'un cadre éprouvé, reconnu et auditable. Ce chapitre présente la famille de normes et le SMSI qu'elle définit.

Plan du chapitre.

1. La famille 27000 (section 7.1).
2. Exigences et lignes directrices (section 7.2).
3. Le SMSI selon la norme (section 7.3).
4. Le principe de la certification (section 7.4).
5. La mairie dans le cadre (section 7.5).

❍

© MaletYon

7.1 La Famille 27000

Norme	Objet
ISO/IEC 27000	Vue d'ensemble et vocabulaire
ISO/IEC 27001	Exigences du SMSI (la seule certifiable)
ISO/IEC 27002	Mesures de sécurité (code de bonne pratique)
ISO/IEC 27005	Gestion des risques de sécurité de l'information
ISO/IEC 27004	Mesure, indicateurs et évaluation
ISO/IEC 27006	Exigences des organismes de certification

Tableau 7.1. Quelques normes de la famille ISO/IEC 27000

La famille forme un système cohérent : la 27001 *exige*, les autres *aident*. On ne se certifie que sur la 27001 ; les autres soutiennent sa mise en œuvre.

7.2 Exigences et Lignes Directrices

Définition

Une norme d'**exigences** ([ISO/IEC 27001]) énonce ce qui *doit* être fait pour être conforme ; ses clauses emploient « doit ». Une norme de **lignes directrices** (27002, 27005) propose des bonnes pratiques ; elle emploie « il convient de ».

La distinction est capitale en audit : un auditeur vérifie le respect des *exigences* de la 27001. Les lignes directrices éclairent le « comment », sans être, elles, directement certifiables.

7.3 Le SMSI selon la Norme

Le SMSI de la 27001 s'articule en sept clauses d'exigences (clauses 4 à 10), qui suivent le cycle PDCA :

Clause	Exigence	Étape PDCA
4	Contexte de l'organisme	Plan
5	Leadership	Plan
6	Planification	Plan
7	Support	Do
8	Fonctionnement	Do
9	Évaluation des performances	Check
10	Amélioration	Act

Tableau 7.2. Les clauses d'exigences et le PDCA

Les Chapitres 8 et 9 détaillent ces clauses ; le Chapitre 10 traite les mesures de l'Annexe A.

7.4 Le Principe de la Certification

Définition

Certification [ISO/IEC 27001] : attestation, délivrée par un organisme accrédité, qu'un SMSI satisfait aux exigences de la norme sur un périmètre défini. Elle se gagne par un audit et se maintient par des audits de surveillance.

La certification ne prouve pas l'absence d'incident : elle atteste que l'organisation *gère* sa sécurité selon la norme. C'est une reconnaissance de maturité, non une garantie d'invulnérabilité.

Application Auditeur SMSI

Auditer l'exigence, pas l'intention. L'auditeur ne note pas la bonne volonté : il vérifie, preuve à l'appui, que chaque « doit » de la norme est satisfait. Une mairie motivée mais sans preuves échoue.

7.5 La Mairie dans le Cadre

Mesure

Constatation. La mairie d'Eséka vise la certification [ISO/IEC 27001] de son SMSI sur le périmètre « services aux usagers » (état civil, taxes).

Analyse. Le choix du périmètre est stratégique : commencer par un périmètre maîtrisable, quitte à l'étendre ensuite. Les quatre phases du fil rouge (Nyong, Kellé, Makak, Matomb) couvrent les clauses 4 à 10.

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **famille 27000** forme un système : la 27001 exige, les autres aident.
- Seule **ISO/IEC 27001** est **certifiable** ; elle emploie « doit ».
- Le **SMSI** de la norme tient en sept clauses (4 à 10) alignées sur le PDCA.
- La **certification** atteste la maîtrise, non l'absence d'incident.
- La mairie vise un **périmètre** défini et maîtrisable.

Note

Points de contrôle de l'élève. Je sais : citer les normes de la famille 27000 ; distinguer exigences et lignes directrices ; énoncer les sept clauses ; expliquer la certification ; définir un périmètre.

✍ Exercice 7.1. La famille ★☆☆

Associez chaque norme à son objet : 27001, 27002, 27005.

✍ Exercice 7.2. Doit ou il convient ★☆☆

Laquelle de ces normes emploie « doit » : 27001 ou 27002 ? Pourquoi est-ce important ?

✍ Exercice 7.3. Les clauses ★☆☆

Citez les sept clauses d'exigences de la 27001 et leur étape PDCA.

✍ Exercice 7.4. Ce que prouve la certification ★★☆

« Une mairie certifiée ne peut pas être victime d'un incident. » Corrigez cette affirmation.

✍ Exercice 7.5. Rôle des lignes directrices ★★☆

À quoi servent la 27002 et la 27005 si l'on se certifie sur la 27001 ?

✍ Exercice 7.6. Périmètre ★★☆

Pourquoi la mairie commence-t-elle par un périmètre restreint ?

✍ Exercice 7.7. Preuve ★★☆

Pourquoi une mairie motivée mais sans preuves échoue-t-elle à l'audit ?

✍ Exercice 7.8. PDCA et clauses ★★☆

Reliez les clauses 9 et 10 aux étapes Check et Act, avec un exemple.

✍ Exercice 7.9. Carte des normes ★★★

Dressez une carte des normes 27000 utiles à la mairie, en indiquant pour chaque étape du projet laquelle mobiliser.

✍ Exercice 7.10. Note de périmètre ★★★

Rédigez la note qui définit et justifie le périmètre de certification de la mairie d'Eséka.

● Note

Pour aller plus loin.

➢ ISO/IEC 27000 [9] ; ISO/IEC 27001 [10].

Note

Transition. Le Chapitre 8 entre dans les premières clauses : contexte, leadership et planification.

8

CONTEXTE, LEADERSHIP, PLANIFICATION

« Avant de planifier la sécurité, il faut savoir pour qui, contre quoi et dans quelles limites. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 7.

✦ Objectifs du chapitre

- ➢ Déterminer le contexte et les parties intéressées (clause 4).
- ➢ Préciser le domaine d'application du SMSI.
- ➢ Caractériser le leadership exigé de la direction (clause 5).
- ➢ Planifier les actions face aux risques et les objectifs (clause 6).
- ➢ Comprendre le lien entre objectifs de sécurité et appréciation des risques.

Question directrice : comment poser les fondations d'un SMSI conforme ?

Les trois premières clauses d'exigences fixent le cadre : qui, quoi, pourquoi, et avec quels objectifs. Ce chapitre les traduit pour la mairie d'Eséka.

Plan du chapitre.

1. Le contexte (clause 4) (section 8.1).
2. Le domaine d'application (section 8.2).
3. Le leadership (clause 5) (section 8.3).
4. La planification (clause 6) (section 8.4).
5. Les objectifs de sécurité (section 8.5).

© *MaletYon*

8.1 Le Contexte (Clause 4)

Définition

La clause 4 exige de déterminer les **enjeux internes et externes** pertinents, les **parties intéressées** et leurs attentes, puis de fixer le **domaine d'application** du SMSI.

Élément	Pour la mairie d'Eséka
Enjeux externes	Loi 2024/017, attentes des usagers, menace cyber
Enjeux internes	Budget contraint, compétences limitées, matériel vieillissant
Parties intéressées	Usagers, tutelle, ANTIC, prestataires, agents

Tableau 8.1. Le contexte de la mairie (clause 4)

8.2 Le Domaine d'Application

Le **domaine d'application** (*scope*) dit ce que couvre le SMSI : quels services, sites, actifs et exclusions. Il doit être écrit et justifié : un périmètre flou rend l'audit impossible.

Mesure

Constatation. La mairie fixe le domaine : « le système d'information des services aux usagers de la mairie d'Eséka (état civil et taxes), à l'exclusion du réseau technique de la voirie ».

Analyse. L'exclusion est explicite et justifiée (la voirie ne traite pas de données sensibles). Un domaine clair protège contre l'extension incontrôlée et cadre l'audit.

8.3 Le Leadership (Clause 5)

La clause 5 exige que la direction **démontre** son leadership : établir la politique, attribuer rôles et responsabilités, fournir les ressources, promouvoir l'amélioration continue. Ce n'est pas une déclaration : ce sont des actes vérifiables (Chapitre 4).

Application Direction générale

Des preuves de leadership. Le maire prouve son engagement par une politique signée, un budget voté, une RSSI nommée et sa présence au comité. L'auditeur demandera ces preuves ; les bonnes intentions ne comptent pas.

8.4 La Planification (Clause 6)

Définition

La clause 6 exige de planifier les **actions face aux risques et opportunités**, de définir le **processus d'appréciation et de traitement des risques**, et de fixer des **objectifs de sécurité** mesurables.

La planification est le cœur « Plan » du PDCA. C'est ici que la norme renvoie à l'appréciation des risques (partie IV) : on ne planifie pas au hasard, mais au vu des risques appréciés.

8.5 Les Objectifs de Sécurité

Définition

Un **objectif de sécurité** est un résultat visé, cohérent avec la politique, *mesurable*, suivi et mis à jour. « Améliorer la sécurité » n'est pas un objectif ; « sauvegarder quotidiennement l'état civil et le vérifier chaque mois » en est un.

Objectif	Indicateur	Cible
Sauvegarder l'état civil	Fréquence	Quotidienne
Former les agents	Taux de formation	100 % en 6 mois
Réduire les accès partagés	Comptes nominatifs	100 %

Tableau 8.2. Des objectifs de sécurité mesurables

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **clause 4** détermine contexte, parties intéressées et domaine d'application.
- Le **domaine d'application** doit être écrit, justifié, avec ses exclusions.
- La **clause 5** exige un leadership *prouvé* de la direction.
- La **clause 6** planifie les actions face aux risques et fixe les objectifs.
- Un **objectif** de sécurité est mesurable et suivi.

Note

Points de contrôle de l'élève. Je sais : déterminer le contexte et les parties intéressées ; rédiger un domaine d'application ; citer les preuves de leadership ; expliquer la planification ; formuler un objectif mesurable.

✍ Exercice 8.1. Contexte ★☆☆

Donnez deux enjeux externes et deux enjeux internes de la mairie d'Eséka.

✍ Exercice 8.2. Parties intéressées ★☆☆

Citez quatre parties intéressées et une attente de sécurité pour chacune.

✍ Exercice 8.3. Objectif mesurable ★☆☆

Transformez « mieux gérer les mots de passe » en objectif mesurable.

✍ Exercice 8.4. Domaine d'application ★★☆

Rédigez le domaine d'application du SMSI de la mairie, avec une exclusion justifiée.

✍ Exercice 8.5. Preuves de leadership ★★☆

Citez quatre preuves par lesquelles le maire démontre son leadership.

✍ Exercice 8.6. Périmètre flou ★★☆

Pourquoi un domaine d'application flou rend-il l'audit impossible ?

✍ Exercice 8.7. Planifier par le risque ★★☆

Expliquez pourquoi la clause 6 renvoie à l'appréciation des risques.

✍ Exercice 8.8. Trois objectifs ★★☆

Proposez trois objectifs de sécurité mesurables pour la mairie, avec cible.

✍ Exercice 8.9. Dossier de contexte ★★★

Rédigez le dossier de contexte (clause 4) complet de la mairie d'Eséka.

✍ Exercice 8.10. Plan d'objectifs ★★★

Construisez un tableau de cinq objectifs de sécurité, avec indicateur, cible, responsable et échéance.

Note

Pour aller plus loin.

➢ ISO/IEC 27001, clauses 4 à 6 [10].

Note

Transition. Le Chapitre 9 poursuit avec le support, le fonctionnement, l'évaluation et l'amélioration (clauses 7 à 10).

9

SUPPORT, FONCTIONNEMENT, ÉVALUATION, AMÉLIORATION

« Un système se juge à ce qu'il produit comme preuves, pas à ce qu'il déclare comme intentions. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 8.

✦ Objectifs du chapitre

- ➢ Identifier les ressources, compétences et communications exigées (clause 7).
- ➢ Comprendre l'exigence d'informations documentées.
- ➢ Décrire le fonctionnement et la maîtrise opérationnelle (clause 8).
- ➢ Expliquer l'évaluation des performances (clause 9).
- ➢ Caractériser l'amélioration et les non-conformités (clause 10).

Question directrice : comment faire vivre et prouver le SMSI ?

Les clauses 7 à 10 font fonctionner le SMSI, le mesurent et l'améliorent. Elles correspondent aux étapes Do, Check et Act du PDCA. Ce chapitre les parcourt pour la mairie.

Plan du chapitre.

1. Le support (clause 7) (section 9.1).
2. Les informations documentées (section 9.2).
3. Le fonctionnement (clause 8) (section 9.3).
4. L'évaluation des performances (clause 9) (section 9.4).
5. L'amélioration (clause 10) (section 9.5).

© *MaletYon*

9.1 Le Support (Clause 7)

Définition

La clause 7 exige de fournir les **ressources**, d'assurer les **compétences**, la **sensibilisation**, la **communication** et la maîtrise des **informations documentées**.

Un SMSI sans moyens ni agents formés reste un document. La mairie doit budgéter la sécurité, former ses agents (Chapitre 15) et communiquer ses règles.

9.2 Les Informations Documentées

Définition

Information documentée : document ou enregistrement que la norme exige de tenir à jour et de maîtriser (politique, procédures, registres, preuves d'audit). « Documenté » signifie tracé et retrouvable.

La maîtrise documentaire est l'épine dorsale de l'audit : ce qui n'est pas documenté est réputé ne pas exister. Chaque exigence satisfaite laisse une preuve écrite.

Mesure

Constatation. La mairie sauvegarde l'état civil mais n'en conserve aucune trace écrite (ni journal, ni test de restauration).

Analyse. Même réelle, la sauvegarde est invérifiable : sans information documentée, l'auditeur ne peut la constater. La mesure existe sans preuve : en audit, elle ne compte pas.

9.3 Le Fonctionnement (Clause 8)

La clause 8 exige de **planifier et maîtriser** les opérations, de réaliser l'**appréciation des risques** à intervalles planifiés et de mettre en œuvre le **traitement des risques**. C'est le « Do » du cycle : on exécute ce que la planification a décidé (parties IV et V).

9.4 L'Évaluation des Performances (Clause 9)

Exigence	Contenu
Surveillance et mesure	Suivre les indicateurs de sécurité
Audit interne	Vérifier la conformité du SMSI
Revue de direction	La direction examine et décide

Tableau 9.1. L'évaluation des performances (clause 9)

La clause 9 est le « Check » : mesurer (Chapitre 18), auditer et passer en revue de direction (Chapitre 19). Sans mesure, on ne sait pas si le SMSI fonctionne.

9.5 L'Amélioration (Clause 10)

Définition

La clause 10 exige de traiter les **non-conformités** par des actions correctives qui en éliminent la cause, et d'assurer l'**amélioration continue** du SMSI.

C'est le « Act » : corriger les écarts à leur cause (Chapitre 3) et relancer le cycle. La boucle est bouclée : de la planification (clause 6) à l'amélioration (clause 10), le SMSI tourne.

Application RSSI

Documenter pour durer. La RSSI tient un dossier vivant : politique, appréciation des risques, plan de traitement, journaux, rapports d'audit, revues de direction. Ce dossier *est* la preuve que le SMSI fonctionne.

À retenir

Ce qu'il faut retenir de ce chapitre :

- La **clause 7** fournit ressources, compétences, communication et informations documentées.
- Ce qui n'est pas **documenté** est réputé inexistant en audit.
- La **clause 8** exécute l'appréciation et le traitement des risques.
- La **clause 9** mesure, audite et passe en revue de direction.
- La **clause 10** corrige à la cause et améliore en continu.

Note

Points de contrôle de l'élève. Je sais : citer les exigences de support ; définir une information documentée ; expliquer le fonctionnement ; décrire l'évaluation des performances ; caractériser l'amélioration.

Exercice 9.1. La clause 7 ★☆☆

Citez trois éléments de support exigés par la clause 7.

Exercice 9.2. Documenté ★☆☆

Qu'entend la norme par « information documentée » ? Donnez deux exemples.

✍ Exercice 9.3. Les trois exigences ★☆☆

Citez les trois exigences de l'évaluation des performances (clause 9).

✍ Exercice 9.4. Mesure sans preuve ★★☆

Pourquoi une sauvegarde réelle mais non tracée ne compte-t-elle pas en audit ?

✍ Exercice 9.5. PDCA et clauses ★★☆

Reliez les clauses 7 à 10 aux étapes Do, Check et Act.

✍ Exercice 9.6. Non-conformité ★★☆

Distinguez corriger une non-conformité et en traiter la cause, par un exemple.

✍ Exercice 9.7. Dossier de preuves ★★☆

Listez cinq documents du dossier du SMSI de la mairie.

✍ Exercice 9.8. Revue de direction ★★☆

À quoi sert la revue de direction, et qui y participe ?

✍ Exercice 9.9. Procédure documentaire ★★★

Rédigez la procédure de maîtrise des informations documentées de la mairie (création, validation, diffusion, archivage).

✍ Exercice 9.10. Tableau clauses-preuves ★★★

Pour chaque clause 7 à 10, indiquez une preuve documentée que la mairie devra produire en audit.

Note

Pour aller plus loin.

➢ ISO/IEC 27001, clauses 7 à 10 [10].

Note

Transition. Les exigences posées, reste le catalogue des mesures : le Chapitre 10 présente **[ISO/IEC 27002]** et l'Annexe A.

10

ISO/IEC 27002 ET LES MESURES DE SÉCURITÉ

« Les mesures ne se choisissent pas dans un catalogue par goût : elles se justifient par le risque. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 7.

✦ Objectifs du chapitre

- ➢ Situer [ISO/IEC 27002] et l'Annexe A de la 27001.
- ➢ Énoncer les quatre thèmes de mesures de la version 2022.
- ➢ Comprendre la structure d'une mesure (attributs, objectif).
- ➢ Relier mesures et appréciation des risques.
- ➢ Introduire la déclaration d'applicabilité.

Question directrice : parmi toutes les mesures possibles, lesquelles retenir ?

La 27002 décrit des dizaines de mesures. La mairie ne les appliquera pas toutes : elle retiendra celles que son risque justifie. Ce chapitre présente le catalogue et prépare le choix.

Plan du chapitre.

1. 27002 et Annexe A (section 10.1).
2. Les quatre thèmes (section 10.2).
3. Structure d'une mesure (section 10.3).
4. Mesures et risques (section 10.4).
5. Vers la déclaration d'applicabilité (section 10.5).

❍

© MaletYon

10.1 27002 et Annexe A

Définition

L'**Annexe A** de **[ISO/IEC 27001]** liste les mesures de sécurité de référence. La norme **[ISO/IEC 27002]** en donne le **guide de mise en œuvre** : pour chaque mesure, son objectif et des conseils d'application.

L'Annexe A fournit la liste de contrôle ; la 27002 explique comment faire. La version 2022 réorganise les mesures en quatre thèmes et introduit des **attributs** (type de mesure, propriété de sécurité, fonction).

10.2 Les Quatre Thèmes

Thème	Nombre	Exemples
Organisationnelles	37	Politiques, rôles, fournisseurs, incidents
Liées aux personnes	8	Sensibilisation, filtrage, télétravail
Physiques	14	Accès aux locaux, supports, équipements
Technologiques	34	Accès, chiffrement, journalisation, sauvegarde

Tableau 10.1. Les quatre thèmes de l'ISO/IEC 27002:2022

Au total, 93 mesures. Les parties V du cours détaillent les mesures organisationnelles et humaines (Chapitre 15), techniques (Chapitre 16) et de continuité (Chapitre 17).

10.3 Structure d'une Mesure

Mesure

Constatation. La mesure « sauvegarde de l'information » (27002) a pour objectif de garantir la *disponibilité* ; ses attributs la classent en mesure préventive et corrective.

Analyse. Chaque mesure a un objectif (ce qu'elle protège) et un guide (comment l'appliquer). À la mairie, cette mesure impose une règle de sauvegarde quotidienne et un test de restauration (Chapitre 17).

Comprendre la structure évite l'application mécanique : on applique une mesure pour son *objectif*, pas pour cocher une case.

10.4 Mesures et Risques

La norme est claire : on ne retient pas une mesure parce qu'elle figure dans l'Annexe A, mais parce que l'**appréciation des risques** (partie IV) la justifie. Les mesures sont la réponse au risque, pas une liste à appliquer en bloc.

Application Auditeur SMSI

La traçabilité risque-mesure. L'auditeur vérifie que chaque mesure retenue répond à un risque identifié, et que chaque risque significatif reçoit une mesure. Une mesure sans risque et un risque sans mesure sont deux écarts.

10.5 Vers la Déclaration d'Applicabilité

Définition

La **déclaration d'applicabilité** (DdA, *Statement of Applicability*) : document qui, pour chaque mesure de l'Annexe A, indique si elle est retenue, sa justification, et son état de mise en œuvre.

La DdA est la pièce maîtresse qui relie les risques aux mesures. Elle est détaillée au Chapitre 14, après l'étude des risques. Retenir ou écarter une mesure s'y justifie explicitement.

À retenir

Ce qu'il faut retenir de ce chapitre :

- L'**Annexe A** liste les mesures ; la **27002** guide leur mise en œuvre.
- La version 2022 compte **93 mesures** en quatre thèmes.
- Chaque mesure a un **objectif** ; on l'applique pour cet objectif.
- Les mesures se justifient par le **risque**, non par le catalogue.
- La **déclaration d'applicabilité** relie risques et mesures.

Note

Points de contrôle de l'élève. Je sais : distinguer Annexe A et 27002 ; citer les quatre thèmes ; décrire la structure d'une mesure ; relier mesure et risque ; définir la DdA.

Exercice 10.1. Annexe A ou 27002 ★☆☆

Laquelle liste les mesures, laquelle en guide la mise en œuvre ?

Exercice 10.2. Les quatre thèmes ★☆☆

Citez les quatre thèmes de mesures et un exemple pour chacun.

✍ Exercice 10.3. Objectif d'une mesure ★☆☆

Quel est l'objectif de la mesure « sauvegarde de l'information » ?

✍ Exercice 10.4. Mesure et risque ★★☆

Pourquoi n'applique-t-on pas toutes les mesures de l'Annexe A ?

✍ Exercice 10.5. Classer des mesures ★★☆

Classez par thème : chiffrement, sensibilisation, contrôle d'accès aux locaux, gestion des fournisseurs.

✍ Exercice 10.6. Deux écarts ★★☆

Qu'est-ce qu'une « mesure sans risque » et un « risque sans mesure » ?

✍ Exercice 10.7. Mesures pour la mairie ★★☆

Citez trois mesures de l'Annexe A particulièrement utiles à la mairie d'Eséka.

✍ Exercice 10.8. Rôle de la DdA ★★☆

À quoi sert la déclaration d'applicabilité ?

✍ Exercice 10.9. Fiche de mesure ★★★

Rédigez une fiche de mesure pour « contrôle d'accès » (objectif, mise en œuvre à la mairie, preuve attendue).

✍ Exercice 10.10. Extrait de DdA ★★★

Rédigez un extrait de DdA pour cinq mesures (retenue ? justification ? état ?).

Note

Pour aller plus loin.

➢ ISO/IEC 27002 [11] ; ISO/IEC 27001, Annexe A [10].

Note

Transition. Choisir des mesures suppose de connaître ses risques : la partie IV s'ouvre au Chapitre 11 sur le vocabulaire du risque.

partie IV

L'Appréciation et le Traitement des Risques

© MaletYon

11

CONCEPTS ET VOCABULAIRE DU RISQUE

« On ne traite bien que les risques que l'on a su nommer. »

Principe du cours

Niveau : *Fondamental* • La partie III.

✦ Objectifs du chapitre

- ➢ Définir actif, menace, vulnérabilité, impact et probabilité.
- ➢ Énoncer les formules du risque et les interpréter.
- ➢ Distinguer risque inhérent et risque résiduel.
- ➢ Comprendre l'appétence et les critères d'acceptation du risque.
- ➢ Appliquer le vocabulaire à un cas de la mairie.

Question directrice : qu'est-ce, au juste, qu'un risque ?

Le mot « risque » est employé à tort et à travers. Pour l'apprécier, il faut le décomposer en éléments précis. Ce chapitre fixe le vocabulaire commun à toutes les méthodes.

Plan du chapitre.

1. Les cinq notions (section 11.1).
2. La formule du risque (section 11.2).
3. Inhérent et résiduel (section 11.3).
4. Appétence et acceptation (section 11.4).
5. Un cas appliqué (section 11.5).

© *MaletYon*

11.1 Les Cinq Notions

Définition

- ➢ **Actif** : élément de valeur à protéger.
- ➢ **Menace** : cause potentielle d'un incident indésirable.
- ➢ **Vulnérabilité** : faiblesse exploitable par une menace.
- ➢ **Impact** : conséquence d'un incident.
- ➢ **Probabilité** (ou vraisemblance) : chance qu'un incident se produise.

Ces notions s'enchaînent : une *menace* exploite une *vulnérabilité* d'un *actif*, avec une certaine *probabilité*, et produit un *impact*. Supprimer l'un des maillons, c'est réduire le risque.

11.2 La Formule du Risque

Définition

Le **risque** se formule, selon le niveau de détail, par :

$$\text{Risque} = \text{Menace} \times \text{Vulnérabilité} \times \text{Impact} \quad \text{ou} \quad \text{Risque} = \text{Probabilité} \times \text{Impact}.$$

Ces formules ne sont pas des calculs exacts mais des *grilles de raisonnement* : elles rappellent que le risque croît avec la probabilité et avec l'impact, et qu'un impact nul (actif sans valeur) annule le risque.

11.3 Inhérent et Résiduel

Définition

Risque inhérent : niveau de risque avant toute mesure. **Risque résiduel** : niveau qui subsiste après traitement. Le risque résiduel n'est jamais nul : il est accepté, explicitement, par la direction.

Distinguer les deux évite deux illusions : croire qu'on part de zéro (il y a toujours un risque inhérent) et croire qu'on arrive à zéro (il reste toujours un résiduel). Le management consiste à ramener le résiduel sous un seuil accepté.

11.4 Appétence et Acceptation

Définition

Appétence au risque : niveau de risque que l'organisation est prête à accepter. Les **critères d'acceptation** traduisent cette appétence en seuils concrets.

Pour une mairie, l'appétence est faible sur l'état civil (qui fait foi) et plus élevée sur le site web d'information. Fixer l'appétence est une décision de gouvernance (le maire),

pas un choix technique.

Application RSSI

Chiffrer sans faux-semblant. La RSSI sait que « Risque = P × I » ne produit pas un nombre scientifique, mais un classement défendable. L'important n'est pas la précision du chiffre : c'est la cohérence du classement et la traçabilité du raisonnement.

11.5 Un Cas Appliqué

Actif · Le registre d'état civil

Constatation. Actif : registre d'état civil numérisé. Menace : rançongiciel apporté par clé `USB`. Vulnérabilité : pas de sauvegarde, accès partagé. Impact : service à l'arrêt, actes indisponibles.

Analyse (confiance élevée). Probabilité élevée (la menace s'est déjà réalisée), impact majeur : risque inhérent très élevé. Deux mesures, la sauvegarde quotidienne et l'interdiction des clés personnelles, réduisent la probabilité et l'impact, abaissant le risque résiduel à un niveau acceptable.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Un risque enchaîne **actif, menace, vulnérabilité, probabilité, impact**.
- Les **formules** du risque sont des grilles de raisonnement, non des calculs exacts.
- Le **risque résiduel** subsiste toujours et s'accepte explicitement.
- L'**appétence** au risque est une décision de gouvernance.
- Le vocabulaire s'applique à chaque **actif** de la mairie.

Note

Points de contrôle de l'élève. Je sais : définir les cinq notions ; énoncer les formules du risque ; distinguer inhérent et résiduel ; expliquer l'appétence ; analyser un cas.

Exercice 11.1. Les cinq notions ★☆☆

Définissez actif, menace, vulnérabilité, impact et probabilité.

✍ Exercice 11.2. La chaîne ★☆☆

Pour le vol du fichier des contribuables, nommez la menace, la vulnérabilité et l'impact.

✍ Exercice 11.3. Inhérent ou résiduel ★☆☆

Un risque « avant toute mesure » est-il inhérent ou résiduel ?

✍ Exercice 11.4. Formule ★★☆

Pourquoi un impact nul annule-t-il le risque, même si la probabilité est élevée ?

✍ Exercice 11.5. Résiduel jamais nul ★★☆

Expliquez pourquoi le risque résiduel n'est jamais nul.

✍ Exercice 11.6. Appétence ★★☆

Pourquoi l'appétence au risque de la mairie diffère-t-elle entre l'état civil et le site web ?

✍ Exercice 11.7. Casser un maillon ★★☆

Montrez qu'agir sur la vulnérabilité réduit le risque, sur l'exemple de la mairie.

✍ Exercice 11.8. Chiffre défendable ★★☆

« Risque = P × I donne un nombre scientifique. » Nuancez.

✍ Exercice 11.9. Analyse d'actif ★★★

Analysez le risque sur la messagerie de la mairie (actif, menace, vulnérabilité, probabilité, impact, inhérent, résiduel).

✍ Exercice 11.10. Critères d'acceptation ★★★

Proposez des critères d'acceptation du risque pour la mairie d'Eséka.

Note

Pour aller plus loin.

➢ ISO/IEC 27005 [12] ; ISO 31000 [5].

Note

Transition. Le vocabulaire posé, le Chapitre 12 présente les méthodes qui l'appliquent : EBIOS RM, OCTAVE, MEHARI.

12

LES MÉTHODES D'APPRÉCIATION DES RISQUES

« Une méthode ne supprime pas le jugement :
elle le rend traçable et partageable. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 11.

✦ Objectifs du chapitre

- ➢ Présenter EBIOS Risk Manager et ses cinq ateliers.
- ➢ Décrire la méthode OCTAVE et ses trois phases.
- ➢ Situer MEHARI et son approche par bases de connaissances.
- ➢ Comparer les méthodes et choisir selon le contexte.
- ➢ Appliquer une démarche d'appréciation à la mairie.

Question directrice : comment conduire une appréciation des risques sans se perdre ?

Apprécier les risques « à l'intuition » produit des oublis et des injustices. Les méthodes structurent la démarche. Ce chapitre présente les principales et aide à choisir.

Plan du chapitre.

1. EBIOS Risk Manager (section 12.1).
2. OCTAVE (section 12.2).
3. MEHARI (section 12.3).
4. Comparer et choisir (section 12.4).
5. Appliquer à la mairie (section 12.5).

© MaletYon

12.1 EBIOS Risk Manager

Définition

EBIOS Risk Manager : méthode française d'appréciation et de traitement des risques numériques, publiée par l'ANSSI, organisée en cinq ateliers.

Atelier	Nom	Produit
1	Cadrage et socle	Périmètre, valeurs métier, socle de sécurité
2	Sources de risque	Qui menace, pour quels objectifs
3	Scénarios stratégiques	Chemins d'attaque de haut niveau
4	Scénarios opérationnels	Chemins techniques détaillés
5	Traitement du risque	Mesures, risques résiduels

Tableau 12.1. Les cinq ateliers d'EBIOS Risk Manager

EBIOS RM met l'accent sur les *sources de risque* et les *scénarios* : elle part de qui veut nuire et pourquoi, plutôt que d'une liste de vulnérabilités.

12.2 OCTAVE

Définition

OCTAVE (*Operationally Critical Threat, Asset and Vulnerability Evaluation*) : méthode centrée sur les actifs critiques, organisée en trois phases.

1. **Profils de menaces fondés sur les actifs** : identifier les actifs critiques et les menaces qui les visent.
2. **Vulnérabilités de l'infrastructure** : analyser les faiblesses techniques.
3. **Stratégie et plan de sécurité** : évaluer impact et probabilité, bâtir le plan.

OCTAVE est conduite par l'organisation elle-même, ce qui favorise l'appropriation.

12.3 MEHARI

Définition

MEHARI (Méthode Harmonisée d'Analyse de Risques) : méthode du CLUSIF s'appuyant sur des bases de connaissances pour évaluer l'exposition et l'efficacité des mesures.

MEHARI propose une analyse fine en situation normale, en cas de dysfonctionnement majeur, et par la vulnérabilité. Son atout est la richesse de ses bases ; son coût, leur lourdeur pour une petite structure.

12.4 Comparer et Choisir

Méthode	Force	Convient à
EBIOS RM	Scénarios, sources de risque	Projets structurés, lien ISO 27005
OCTAVE	Appropriation interne	Organisations qui s'auto-évaluent
MEHARI	Bases de connaissances	Structures matures et outillées

Tableau 12.2. Choisir une méthode selon le contexte

Aucune méthode n'est « la meilleure » : la bonne est celle que l'organisation peut réellement conduire. Toutes sont compatibles avec **[ISO/IEC 27005]**.

12.5 Appliquer à la Mairie

Mesure

Constatation. La mairie d'Eséka, aux moyens limités, choisit EBIOS RM pour l'opération Kellé, en version allégée.

Analyse. Le choix est cohérent : EBIOS RM est publique, gratuite, outillée, et son approche par scénarios parle aux élus (qui veut nuire à la mairie, et comment). Une version allégée évite la lourdeur pour une petite structure.

Application RSSI

Adapter, pas appliquer à la lettre. La RSSI adapte la méthode à la taille de la mairie : cinq ateliers menés en une journée d'atelier collectif, plutôt qu'une étude de plusieurs mois. La méthode sert le projet, pas l'inverse.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **EBIOS RM** (ANSSI) structure l'appréciation en cinq ateliers, centrés sur les scénarios.
- **OCTAVE** part des actifs critiques en trois phases, par auto-évaluation.
- **MEHARI** s'appuie sur des bases de connaissances, pour structures matures.
- On **choisit** la méthode que l'organisation peut conduire ; toutes sont compatibles ISO 27005.
- La mairie adopte **EBIOS RM allégée** pour l'opération Kellé.

Note

Points de contrôle de l'élève. Je sais : citer les cinq ateliers d'EBIOS RM ; décrire les trois phases d'OCTAVE ; situer MEHARI ; comparer les méthodes ; justifier un choix.

✍ Exercice 12.1. Les ateliers ★☆☆

Citez les cinq ateliers d'EBIOS Risk Manager.

✍ Exercice 12.2. Les phases ★☆☆

Énoncez les trois phases d'OCTAVE.

✍ Exercice 12.3. MEHARI ★☆☆

Quel est le principe de MEHARI et son principal atout ?

✍ Exercice 12.4. Source de risque ★★☆

En quoi EBIOS RM se distingue-t-elle en partant des sources de risque ?

✍ Exercice 12.5. Choisir ★★☆

Pour une petite mairie, quelle méthode recommandez-vous ? Justifiez.

✍ Exercice 12.6. Adapter ★★☆

Pourquoi faut-il adapter la méthode à la taille de l'organisation ?

✍ Exercice 12.7. Atelier 1 ★★☆

Que produit l'atelier 1 d'EBIOS RM pour la mairie d'Eséka ?

✍ Exercice 12.8. Compatibilité ISO ★★☆

Pourquoi ces méthodes sont-elles toutes compatibles avec **[ISO/IEC 27005]** ?

✍ Exercice 12.9. Mini-EBIOS ★★★

Conduisez un mini-atelier EBIOS RM sur l'état civil : deux sources de risque, deux scénarios stratégiques.

✍ Exercice 12.10. Note de méthode ★★★

Rédigez la note qui justifie, auprès du maire, le choix de méthode pour l'opération Kellé.

Note

Pour aller plus loin.

➢ EBIOS Risk Manager [2] ; ISO/IEC 27005 [12].

Note

Transition. Les risques appréciés, il faut les cartographier et décider : le Chapitre 13 traite la cartographie et le traitement.

13

CARTOGRAPHIE ET TRAITEMENT DES RISQUES

« Cartographier, c'est transformer une inquiétude diffuse en une liste de décisions à prendre. »

Principe du cours

Niveau : *Intermédiaire* • Les Chapitres 11 et 12.

✦ Objectifs du chapitre

- ➢ Construire et lire une matrice des risques.
- ➢ Hiérarchiser les risques par niveau.
- ➢ Énoncer les quatre stratégies de traitement.
- ➢ Choisir une stratégie selon le risque et le coût.
- ➢ Formaliser le risque résiduel et son acceptation.

Question directrice : une fois les risques connus, que décide-t-on ?

Connaître ses risques ne sert à rien si l'on n'en fait rien. Ce chapitre transforme la liste des risques en décisions : les classer, puis, pour chacun, choisir un traitement.

Plan du chapitre.

1. La matrice des risques (section 13.1).
2. Hiérarchiser (section 13.2).
3. Les quatre stratégies (section 13.3).
4. Choisir un traitement (section 13.4).
5. Le risque résiduel (section 13.5).

© MaletYon

13.1 La Matrice des Risques

Définition

La **matrice des risques** croise la *probabilité* et l'*impact* pour situer chaque risque dans une grille et en déduire un niveau.

Impact / Prob.	Faible	Moyenne	Élevée	Très él.
Mineur	Faible	Faible	Moyen	Moyen
Modéré	Faible	Moyen	Moyen	Élevé
Majeur	Moyen	Moyen	Élevé	Très él.
Critique	Moyen	Élevé	Très él.	Très él.

Tableau 13.1. Matrice probabilité × impact

13.2 Hiérarchiser

La matrice hiérarchise : on traite d'abord les risques « très élevés » et « élevés », on surveille les « moyens », on documente l'acceptation des « faibles ». Cette hiérarchie fonde le **plan de traitement** : on ne peut pas tout traiter en même temps, donc on priorise.

Mesure

Constatation. À Eséka, le risque « perte de l'état civil » est très élevé ; le risque « défiguration du site web » est moyen.

Analyse. La priorité va à l'état civil : impact critique, probabilité démontrée. Le site web, moins critique, sera traité ensuite. Hiérarchiser, c'est choisir où mettre ses moyens limités.

13.3 Les Quatre Stratégies

Définition

Pour chaque risque, quatre **stratégies de traitement** :

- **Éviter** : supprimer la cause (renoncer à l'activité risquée).
- **Réduire** : diminuer la probabilité ou l'impact par des mesures.
- **Transférer** : reporter le risque (assurance, sous-traitance).
- **Accepter** : assumer le risque résiduel en connaissance de cause.

13.4 Choisir un Traitement

Risque	Stratégie	Mesure
Perte de l'état civil	Réduire	Sauvegarde 3-2-1, test de restauration
Fuite du fichier taxes	Réduire	Chiffrement, accès nominatif
Panne électrique	Transférer	Contrat de maintenance, onduleur loué
Site web décoratif	Accepter	Risque résiduel faible, documenté

Tableau 13.2. Choix de traitement à la mairie

Le choix met en balance le *coût* du traitement et le *gain* de réduction du risque : réduire un risque faible à grands frais est un mauvais arbitrage.

Application Direction générale

Accepter est une décision, pas un oubli. Accepter un risque est légitime, à condition que ce soit explicite, documenté et décidé par la direction. Un risque « accepté » par simple inaction n'est pas accepté : il est ignoré.

13.5 Le Risque Résiduel

Après traitement, il reste un **risque résiduel**. La norme exige que la direction l'**accepte formellement** (Chapitre 14). Cette acceptation est tracée : c'est la direction qui porte, en connaissance de cause, ce qui n'a pas été éliminé.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La **matrice** situe chaque risque et en déduit un niveau.
- On **hiérarchise** pour traiter d'abord les risques les plus forts.
- Quatre **stratégies** : éviter, réduire, transférer, accepter.
- On **choisit** en pesant coût et gain.
- Le **risque résiduel** est accepté formellement par la direction.

Note

Points de contrôle de l'élève. Je sais : lire une matrice des risques ; hiérarchiser ; énoncer les quatre stratégies ; choisir un traitement ; expliquer l'acceptation du risque résiduel.

✍ Exercice 13.1. Lire la matrice ★☆☆

Un risque de probabilité élevée et d'impact critique : quel niveau ?

✍ Exercice 13.2. Les stratégies ★☆☆

Citez les quatre stratégies de traitement du risque.

✍ Exercice 13.3. Hiérarchiser ★☆☆

Entre un risque « très élevé » et un « moyen », lequel traite-t-on d'abord ?

✍ Exercice 13.4. Associer ★★☆

Associez une stratégie à chacun : perte de l'état civil ; panne électrique ; site web décoratif.

✍ Exercice 13.5. Coût-gain ★★☆

Pourquoi réduire un risque faible à grands frais est-il un mauvais arbitrage ?

✍ Exercice 13.6. Transférer ★★☆

Donnez un exemple de risque que la mairie peut transférer, et comment.

✍ Exercice 13.7. Accepter ou ignorer ★★☆

Quelle différence entre un risque accepté et un risque ignoré ?

✍ Exercice 13.8. Résiduel ★★☆

Qui accepte le risque résiduel, et pourquoi doit-ce être tracé ?

✍ Exercice 13.9. Cartographie ★★★

Dressez la cartographie de cinq risques de la mairie dans la matrice, avec leur niveau.

✍ Exercice 13.10. Plan de traitement ★★★

Construisez un plan de traitement pour ces cinq risques (stratégie, mesure, responsable, échéance).

Note

Pour aller plus loin.

➢ ISO/IEC 27005 [12] ; ISO 31000 [5].

Note

Transition. Le plan de traitement se formalise dans un document central : le Chapitre 14 présente la déclaration d'applicabilité.

14

LA DÉCLARATION D'APPLICABILITÉ ET LE PLAN DE TRAITEMENT

> « La déclaration d'applicabilité est la carte d'identité du SMSI : elle dit ce qu'on fait, ce qu'on ne fait pas, et pourquoi. »
>
> Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 13.

✦ Objectifs du chapitre

- ➢ Définir la déclaration d'applicabilité (DdA) et son rôle.
- ➢ Construire une DdA à partir des risques et de l'Annexe A.
- ➢ Distinguer DdA et plan de traitement des risques.
- ➢ Justifier l'inclusion et l'exclusion d'une mesure.
- ➢ Faire acter le risque résiduel par la direction.

Question directrice : comment prouver que les mesures retenues sont les bonnes ?

L'auditeur ne croit pas sur parole : il demande à voir le lien entre risques et mesures. La déclaration d'applicabilité est le document qui établit ce lien. Ce chapitre la construit.

Plan du chapitre.

1. Rôle de la DdA (section 14.1).
2. Construire la DdA (section 14.2).
3. DdA et plan de traitement (section 14.3).
4. Inclure, exclure (section 14.4).
5. Acter le risque résiduel (section 14.5).

© MaletYon

14.1 Rôle de la DdA

Définition

La **déclaration d'applicabilité** (DdA) : document exigé par la clause 6.1.3 de [ISO/IEC 27001] qui, pour chaque mesure de l'Annexe A, indique si elle est *retenue*, sa *justification* (inclusion ou exclusion) et son *état* de mise en œuvre.

La DdA est le document que tout auditeur demande en premier : elle résume le SMSI en une page de synthèse et une grille. Elle fait le pont entre la partie IV (risques) et la partie V (mesures).

14.2 Construire la DdA

Mesure (Annexe A)	Retenue	Justification	État
Sauvegarde	Oui	Risque R1 (état civil)	En place
Contrôle d'accès	Oui	Risque R2 (taxes)	En place
Chiffrement	Oui	Risque R2	En cours
Développement sécurisé	Non	Pas de développement interne	Exclue

Tableau 14.1. Extrait de la DdA de la mairie d'Eséka

Chaque ligne relie une mesure à un risque (inclusion) ou explique pourquoi la mesure ne s'applique pas (exclusion). Rien n'est laissé implicite.

14.3 DdA et Plan de Traitement

Définition

Le **plan de traitement des risques** : document qui, pour chaque risque, précise la stratégie, les mesures, le responsable et l'échéance. La DdA dit *quelles* mesures ; le plan dit *comment et quand* les mettre en œuvre.

Les deux documents sont complémentaires : la DdA est la photographie des mesures ; le plan est la feuille de route. Ensemble, ils constituent le « Plan » du PDCA.

14.4 Inclure, Exclure

Mesure

Constatation. La mairie exclut la mesure « développement sécurisé » au motif qu'elle n'écrit aucun logiciel elle-même.

Analyse. L'exclusion est légitime et justifiée : la mesure ne correspond à aucun

risque de la mairie. Mais la justification doit être écrite : une exclusion non justifiée est un écart d'audit. On ne retire une mesure que si le risque associé n'existe pas.

Application Auditeur SMSI

Lire la DdA à rebours. L'auditeur part de la DdA et remonte : cette mesure retenue répond-elle à un risque réel ? cette mesure exclue l'est- elle à bon droit ? La DdA est le fil qui relie tout le SMSI.

14.5 Acter le Risque Résiduel

Une fois la DdA et le plan établis, il reste un risque résiduel. La clause 6.1 exige que les **propriétaires des risques** approuvent le plan de traitement et **acceptent** le risque résiduel. À la mairie, c'est le maire qui signe cette acceptation.

Jurisprudence & Droit applicable

Faire acter le risque résiduel par la direction n'est pas une formalité : c'est l'acte par lequel la responsabilité est assumée au bon niveau. En cas d'incident, cette trace montre que le risque avait été identifié, pesé et décidé, et non ignoré.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La **DdA** indique, pour chaque mesure, si elle est retenue, sa justification et son état.
- Elle se **construit** à partir des risques et de l'Annexe A.
- La **DdA** dit quelles mesures ; le **plan de traitement** dit comment et quand.
- **Inclusion** et **exclusion** se justifient par écrit.
- La direction **accepte** formellement le risque résiduel.

Note

Points de contrôle de l'élève. Je sais : définir la DdA ; la construire ; la distinguer du plan de traitement ; justifier une inclusion ou une exclusion ; expliquer l'acceptation du risque résiduel.

Exercice 14.1. Rôle de la DdA ★☆☆

Qu'indique la DdA pour chaque mesure de l'Annexe A ?

✍ Exercice 14.2. DdA ou plan ★☆☆

Laquelle dit « quelles mesures », lequel dit « comment et quand » ?

✍ Exercice 14.3. Exclusion ★☆☆

Pourquoi la mairie peut-elle exclure la mesure « développement sécurisé » ?

✍ Exercice 14.4. Une ligne ★★☆

Rédigez une ligne de DdA pour la mesure « journalisation ».

✍ Exercice 14.5. Exclusion non justifiée ★★☆

Pourquoi une exclusion non justifiée est-elle un écart d'audit ?

✍ Exercice 14.6. Lire à rebours ★★☆

Comment un auditeur se sert-il de la DdA pour vérifier le SMSI ?

✍ Exercice 14.7. Acceptation ★★☆

Qui, à la mairie, accepte le risque résiduel, et pourquoi la trace importe-t- elle ?

✍ Exercice 14.8. Complémentarité ★★☆

Montrez que DdA et plan de traitement sont complémentaires.

✍ Exercice 14.9. DdA de la mairie ★★★

Construisez un extrait de DdA de huit mesures pour la mairie d'Eséka.

✍ Exercice 14.10. Plan complet ★★★

Rédigez le plan de traitement des risques de la mairie (cinq risques, stratégie, mesures, responsable, échéance, acceptation).

Note

Pour aller plus loin.

➢ ISO/IEC 27001, clause 6.1.3 [10] ; ISO/IEC 27005 [12].

Note

Transition. Le plan décidé, place à la mise en œuvre : la partie V s'ouvre au Chapitre 15 sur les mesures organisationnelles et humaines.

partie V

Mettre en Œuvre les Mesures

© *MaletYon*

15

MESURES ORGANISATIONNELLES ET HUMAINES

« La technique protège les machines ;
la sensibilisation protège les décisions des gens. »

Principe du cours

Niveau : *Intermédiaire* • La partie IV.

✦ Objectifs du chapitre

- ➢ Identifier les mesures organisationnelles clés.
- ➢ Comprendre le poids du facteur humain dans la sécurité.
- ➢ Concevoir une campagne de sensibilisation.
- ➢ Sécuriser le cycle de vie de l'agent (arrivée, mobilité, départ).
- ➢ Encadrer les fournisseurs et le télétravail.

Question directrice : comment agir sur ce qui n'est ni un logiciel ni un câble ?

L'incident de la mairie est né d'un geste humain : brancher une clé. Les mesures techniques ne suffisent pas : il faut agir sur l'organisation et sur les personnes. Ce chapitre traite ces mesures.

Plan du chapitre.

1. Les mesures organisationnelles (section 15.1).
2. Le facteur humain (section 15.2).
3. La sensibilisation (section 15.3).
4. Le cycle de vie de l'agent (section 15.4).
5. Fournisseurs et télétravail (section 15.5).

© MaletYon

15.1 Les Mesures Organisationnelles

Mesure	Ce qu'elle installe
Politiques et procédures	Le cadre écrit des règles
Rôles et responsabilités	Qui fait quoi (matrice RACI)
Classification de l'information	Des niveaux et des règles de manipulation
Gestion des incidents	Un processus de signalement et de traitement
Relations avec les fournisseurs	Des exigences de sécurité contractuelles

Tableau 15.1. Mesures organisationnelles (ISO/IEC 27002)

Ces mesures ne coûtent souvent que du temps et de la rigueur : elles sont les premières à déployer, avant tout investissement technique.

15.2 Le Facteur Humain

Définition

Le **facteur humain** : part des incidents liée aux comportements des personnes (erreur, négligence, manipulation). Il est, dans la plupart des études, la première cause d'incident.

L'agent n'est pas le maillon faible par nature : il le devient faute de formation et de règles claires. Sensibiliser transforme le maillon faible en première ligne de défense.

Scénario Opérationnel · Opération MAKAK. La clé piégée

Constatation. L'agent qui a branché la clé ignorait le risque : il n'avait reçu ni règle écrite, ni formation.

Analyse (confiance élevée). Le reproche ne vise pas l'agent mais l'organisation : sans règle ni sensibilisation, le geste était prévisible. La mesure corrective est double : interdire les clés personnelles *et* former les agents.

15.3 La Sensibilisation

Thème	Message clé
Mots de passe	Individuels, robustes, jamais partagés
Hameçonnage	Vérifier l'expéditeur, ne pas cliquer dans le doute
Supports amovibles	N'utiliser que des supports maîtrisés
Données personnelles	Ne traiter que le nécessaire, protéger
Signalement	Prévenir vite en cas de doute, sans crainte

Tableau 15.2. Thèmes d'une campagne de sensibilisation

Une campagne efficace est régulière, concrète et bienveillante : on apprend à signaler sans être puni. Hameçonnage simulé, affiches et courtes sessions valent mieux qu'un règlement illisible.

Application Responsable conformité

Prouver la sensibilisation. La formation doit être tracée : feuilles d'émargement, attestations, résultats des tests. En audit, « nous sensibilisons nos agents » ne vaut rien sans preuve.

15.4 Le Cycle de Vie de l'Agent

La sécurité suit l'agent de son arrivée à son départ : à l'**arrivée**, charte signée et accès minimal ; en cas de **mobilité**, droits réajustés ; au **départ**, accès révoqués et matériel restitué. Un compte d'agent parti et toujours actif est une porte ouverte.

15.5 Fournisseurs et Télétravail

Mesure

Constatation. L'éditeur du logiciel d'état civil accède à distance aux données de la mairie, sans clause de sécurité au contrat.

Analyse. C'est un risque de tiers : la mairie reste responsable des données que son prestataire manipule. La mesure impose des *exigences de sécurité contractuelles* et un contrôle des accès distants. Le télétravail des agents suit la même logique : règles écrites et moyens maîtrisés.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Les **mesures organisationnelles** posent le cadre écrit, à faible coût.
- Le **facteur humain** est la première cause d'incident ; la formation en fait une défense.
- Une **campagne de sensibilisation** est régulière, concrète, tracée.
- La sécurité suit le **cycle de vie de l'agent**, du recrutement au départ.
- **Fournisseurs** et **télétravail** exigent des règles et des contrats.

Note

Points de contrôle de l'élève. Je sais : citer des mesures organisationnelles ; expliquer le facteur humain ; concevoir une campagne ; sécuriser le cycle de vie de l'agent ; encadrer fournisseurs et télétravail.

✍ Exercice 15.1. Mesures organisationnelles ★☆☆

Citez trois mesures organisationnelles de l'ISO/IEC 27002.

✍ Exercice 15.2. Facteur humain ★☆☆

Pourquoi dit-on que l'humain est la première cause d'incident ?

✍ Exercice 15.3. Thèmes ★☆☆

Citez quatre thèmes d'une campagne de sensibilisation.

✍ Exercice 15.4. Blâmer qui ★★☆

Faut-il blâmer l'agent qui a branché la clé ? Argumentez.

✍ Exercice 15.5. Prouver la formation ★★☆

Comment la mairie prouve-t-elle, en audit, qu'elle sensibilise ses agents ?

✍ Exercice 15.6. Départ d'un agent ★★☆

Quelles actions de sécurité au départ d'un agent ?

✍ Exercice 15.7. Risque de tiers ★★☆

Pourquoi la mairie reste-t-elle responsable des données manipulées par son prestataire ?

✍ Exercice 15.8. Télétravail ★★☆

Citez trois règles de sécurité pour le télétravail d'un agent de la mairie.

✍ Exercice 15.9. Plan de campagne ★★★

Concevez un plan de campagne de sensibilisation sur un an pour la mairie d'Eséka.

✍ Exercice 15.10. Clause fournisseur ★★★

Rédigez une clause de sécurité à insérer au contrat de l'éditeur du logiciel d'état civil.

● Note

Pour aller plus loin.

➢ ISO/IEC 27002, thèmes organisationnel et personnes [11] ; Guide d'hygiène ANSSI [1].

Note

Transition. Les mesures humaines posées, le Chapitre 16 traite les mesures techniques : accès, réseau, chiffrement, journalisation.

16

MESURES TECHNIQUES

« Une bonne mesure technique applique une décision de sécurité ; elle ne la remplace pas. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 15 ; notions de réseaux.

✦ Objectifs du chapitre

- ➢ Distinguer les modèles de contrôle d'accès (DAC, MAC, RBAC).
- ➢ Expliquer l'authentification forte (MFA).
- ➢ Situer pare-feu, VPN et segmentation réseau.
- ➢ Comprendre le rôle du chiffrement et de la journalisation.
- ➢ Relier chaque mesure technique à un critère DIC.

Question directrice : quelles mesures techniques pour quels risques ?

Les mesures techniques sont nombreuses : le danger est de les empiler sans logique. Ce chapitre les présente en les rattachant aux risques et aux critères de sécurité de la mairie.

Plan du chapitre.

1. Le contrôle d'accès (section 16.1).
2. L'authentification forte (section 16.2).
3. La sécurité réseau (section 16.3).
4. Chiffrement et journalisation (section 16.4).
5. Rattacher aux critères (section 16.5).

© MaletYon

16.1 Le Contrôle d'Accès

Modèle	Principe	Exemple
DAC	Fondé sur l'identité, propriétaire	Permissions d'un fichier
MAC	Fondé sur des étiquettes	Politique centralisée (SELinux)
RBAC	Fondé sur les rôles	Un agent d'état civil voit l'état civil

Tableau 16.1. Les modèles de contrôle d'accès

Le **moindre privilège** commande : chacun n'a que les droits nécessaires à sa tâche. À la mairie, le modèle RBAC convient : on donne des droits par rôle (état civil, taxes), non par personne.

16.2 L'Authentification Forte

Définition

Authentification multifacteur (MFA) : vérification de l'identité par au moins deux facteurs parmi : ce que l'on sait (mot de passe), ce que l'on possède (jeton, téléphone), ce que l'on est (biométrie).

La MFA réduit fortement le risque lié aux mots de passe volés ou faibles. Pour les accès sensibles de la mairie (administration du serveur d'état civil), elle devrait être la règle.

16.3 La Sécurité Réseau

Mesure	Rôle
Pare-feu	Filtrer les flux, bloquer par défaut
Segmentation	Isoler les réseaux (postes publics / serveurs)
VPN	Chiffrer les accès distants
IDS/IPS	Détecter ou bloquer les intrusions

Tableau 16.2. Mesures de sécurité réseau

La **segmentation** aurait limité l'incident d'Eséka : si les postes du public avaient été isolés du serveur d'état civil, la clé n'aurait pas tout atteint. Cloisonner, c'est contenir.

16.4 Chiffrement et Journalisation

Définition

Chiffrement : rendre une information inintelligible sans la clé, pour protéger sa *confidentialité*. **Journalisation** : enregistrer les événements du système, pour la *traçabilité* et la détection.

Chiffrer le fichier des contribuables protège sa confidentialité même en cas de vol du support. Journaliser les accès à l'état civil permet de savoir qui a consulté quoi, et soutient l'enquête en cas d'incident (lien avec le cours de forensique, LPI342).

Application DSI

Déployer ce que la politique décide. Le DSI met en œuvre, mais ne décide pas seul : il déploie les mesures que l'appréciation des risques a justifiées et que la politique a actées. La technique sert la décision, pas l'inverse.

16.5 Rattacher aux Critères

Mesure

Constatation. La mairie déploie : RBAC, MFA, segmentation, chiffrement, journalisation, sauvegarde.

Analyse. Chaque mesure sert un critère : contrôle d'accès et chiffrement servent la *confidentialité* ; sauvegarde et segmentation, la *disponibilité* ; journalisation, la *traçabilité* ; signature et contrôle d'intégrité, l'*intégrité*. Rattacher chaque mesure à un critère évite d'en oublier et d'en empiler d'inutiles.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **DAC, MAC, RBAC** : trois modèles de contrôle d'accès ; le **moindre privilège** commande.
- La **MFA** réduit le risque des mots de passe volés.
- **Pare-feu, segmentation, VPN** cloisonnent et protègent le réseau.
- **Chiffrement** (confidentialité) et **journalisation** (traçabilité) sont essentiels.
- Chaque mesure technique se rattache à un **critère DIC**.

Note

Points de contrôle de l'élève. Je sais : distinguer DAC, MAC, RBAC ; expliquer la MFA ; situer les mesures réseau ; décrire chiffrement et journalisation ; rattacher une mesure à un critère.

✍ Exercice 16.1. Les modèles ★☆☆

Distinguez DAC, MAC et RBAC en une phrase chacun.

✍ Exercice 16.2. MFA ★☆☆

Qu'est-ce que la MFA, et quels sont les trois types de facteurs ?

✍ Exercice 16.3. Rôle d'une mesure ★☆☆

À quoi sert la segmentation réseau ?

✍ Exercice 16.4. Moindre privilège ★★☆

Appliquez le moindre privilège aux agents d'état civil et des taxes.

✍ Exercice 16.5. Segmentation ★★☆

Comment la segmentation aurait-elle limité l'incident de la clé `USB` ?

✍ Exercice 16.6. Chiffrer quoi ★★☆

Quelles informations de la mairie chiffreriez-vous en priorité, et pourquoi ?

✍ Exercice 16.7. Journaliser ★★☆

Quels événements journaliser sur le serveur d'état civil ?

✍ Exercice 16.8. Mesure et critère ★★☆

Reliez chaque mesure à un critère DIC : chiffrement, sauvegarde, journalisation, RBAC.

✍ Exercice 16.9. Architecture ★★★

Proposez une architecture réseau segmentée pour la mairie d'Eséka (public, agents, serveurs).

✍ Exercice 16.10. Plan technique ★★★

Dressez le plan des mesures techniques de la mairie, chacune rattachée à un risque et à un critère.

Note

Pour aller plus loin.

➢ ISO/IEC 27002, thème technologique [11] ; Guide d'hygiène ANSSI [1].

Note

Transition. Reste à se préparer au pire : le Chapitre 17 traite la continuité d'activité, PCA et PRA.

17

CONTINUITÉ D'ACTIVITÉ : PCA ET PRA

« Une sauvegarde que l'on n'a jamais restaurée
n'est pas une sauvegarde : c'est un espoir. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 16.

✦ Objectifs du chapitre

- ➢ Distinguer plan de continuité (PCA) et plan de reprise (PRA).
- ➢ Conduire une analyse d'impact sur l'activité (BIA).
- ➢ Définir RTO, RPO, MTTR, MTBF.
- ➢ Appliquer la règle de sauvegarde 3-2-1 et tester les restaurations.
- ➢ Construire une stratégie de continuité adaptée à la mairie.

Question directrice : comment tenir le service quand le pire arrive ?

L'incident a montré qu'une panne peut tout arrêter. La continuité prépare la mairie à tenir et à reprendre. Ce chapitre construit le PCA et le PRA.

Plan du chapitre.

1. PCA et PRA (section 17.1).
2. L'analyse d'impact (section 17.2).
3. Les indicateurs de continuité (section 17.3).
4. Sauvegarde et restauration (section 17.4).
5. La stratégie de la mairie (section 17.5).

© MaletYon

17.1 PCA et PRA

Définition

Plan de continuité d'activité (PCA) : dispositif qui maintient les activités critiques pendant un sinistre, éventuellement en mode dégradé. **Plan de reprise d'activité** (PRA) : dispositif qui rétablit le système après le sinistre. Le PCA tient ; le PRA répare.

Pour la mairie, le PCA permet de continuer à délivrer des actes (même sur registre papier de secours) ; le PRA remet en service le système numérique.

17.2 L'Analyse d'Impact

Définition

Analyse d'impact sur l'activité (BIA) : étude qui identifie les activités critiques, évalue l'impact de leur interruption et fixe les délais tolérables. Elle fonde toute la stratégie de continuité.

Le BIA répond à : quelles activités ne peuvent s'arrêter ? combien de temps peut-on tenir sans elles ? quelle perte de données est tolérable ? À Eséka, l'état civil est l'activité la plus critique.

17.3 Les Indicateurs de Continuité

Indicateur	Définition
RTO	Délai maximal de remise en service visé
RPO	Perte de données maximale acceptable (point de reprise)
MTTR	Temps moyen de réparation
MTBF	Temps moyen entre deux pannes

Tableau 17.1. Indicateurs de continuité

RTO et RPO commandent la stratégie : un RPO d'une heure impose des sauvegardes au moins horaires ; un RTO de quatre heures impose des moyens de reprise rapides.

17.4 Sauvegarde et Restauration

Définition

La règle **3-2-1** : conserver **3** copies des données, sur **2** supports différents, dont **1** hors site. Elle protège contre la panne, l'erreur et le sinistre local.

Mesure

Constatation. Avant la démarche, la mairie avait une seule copie de l'état civil, sur le même serveur que l'original, jamais testée.

Analyse (confiance élevée). Cette « sauvegarde » violait la règle 3-2-1 (une copie, un support, sur site) et n'avait jamais été restaurée : elle ne protégeait rien. La mesure corrective impose trois copies, dont une hors site, et un *test de restauration* mensuel. Une sauvegarde non testée est réputée inexistante.

Application DSI

Tester, pas seulement sauvegarder. Le DSI planifie des tests de restauration réguliers : c'est le seul moyen de savoir que la sauvegarde fonctionne *avant* d'en avoir besoin. Le jour du sinistre est le pire moment pour découvrir qu'elle est illisible.

17.5 La Stratégie de la Mairie

La mairie d'Eséka adopte une stratégie proportionnée : sauvegarde quotidienne de l'état civil selon la règle 3-2-1, copie hors site chez la tutelle, registre papier de secours pour le mode dégradé, et test de restauration mensuel. Le PCA et le PRA sont écrits, diffusés et exercés.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Le **PCA** maintient l'activité ; le **PRA** rétablit le système.
- Le **BIA** identifie les activités critiques et fixe les délais tolérables.
- **RTO** et **RPO** commandent la stratégie de continuité.
- La règle **3-2-1** et le **test de restauration** font d'une copie une vraie sauvegarde.
- La mairie adopte une stratégie **proportionnée** et **exercée**.

Note

Points de contrôle de l'élève. Je sais : distinguer PCA et PRA ; conduire un BIA ; définir RTO, RPO, MTTR, MTBF ; appliquer la règle 3-2-1 ; bâtir une stratégie de continuité.

Exercice 17.1. PCA ou PRA ★☆☆

« Continuer à délivrer des actes pendant la panne » relève-t-il du PCA ou du PRA ?

✍ Exercice 17.2. Les indicateurs ★☆☆

Définissez RTO et RPO.

✍ Exercice 17.3. La règle 3-2-1 ★☆☆

Énoncez la règle 3-2-1 de sauvegarde.

✍ Exercice 17.4. BIA ★★☆

Quelle est l'activité la plus critique de la mairie, et pourquoi ?

✍ Exercice 17.5. RPO et fréquence ★★☆

Un RPO d'une heure impose quelle fréquence de sauvegarde ? Justifiez.

✍ Exercice 17.6. Fausse sauvegarde ★★☆

Pourquoi la « sauvegarde » initiale de la mairie ne protégeait-elle rien ?

✍ Exercice 17.7. Tester ★★☆

Pourquoi faut-il tester les restaurations, et à quelle fréquence ?

✍ Exercice 17.8. Mode dégradé ★★☆

Décrivez un mode dégradé pour l'état civil en cas de panne prolongée.

✍ Exercice 17.9. Stratégie 3-2-1 ★★★

Concevez la stratégie de sauvegarde 3-2-1 complète de la mairie d'Eséka.

✍ Exercice 17.10. PRA rédigé ★★★

Rédigez un plan de reprise d'activité d'une page pour le serveur d'état civil (RTO, RPO, étapes, responsables).

Note

Pour aller plus loin.

➢ ISO 22301 [6] ; ISO/IEC 27002 [11].

Note

Transition. Les mesures en place, il faut les piloter : la partie VI s'ouvre au Chapitre 18 sur la surveillance et les indicateurs.

partie VI

Contrôler, Auditer, Améliorer

© MaletYon

18

SURVEILLANCE, MESURE ET INDICATEURS

« Ce qui ne se mesure pas ne se pilote pas ;
ce qui ne se pilote pas se dégrade. »

Principe du cours

Niveau : *Intermédiaire* • La partie V.

✦ Objectifs du chapitre

- ➢ Comprendre l'exigence de surveillance et de mesure (clause 9.1).
- ➢ Distinguer indicateurs de performance et de risque.
- ➢ Construire un indicateur utile (mesurable, suivi, décidable).
- ➢ Bâtir un tableau de bord de sécurité pour la direction.
- ➢ Relier la mesure à la décision et à l'amélioration.

Question directrice : comment savoir si le SMSI fonctionne vraiment ?

La mairie a déployé des mesures. Fonctionnent-elles ? Sans mesure, nul ne le sait. Ce chapitre construit les indicateurs et le tableau de bord qui répondent.

Plan du chapitre.

1. L'exigence de mesure (section 18.1).
2. Performance et risque (section 18.2).
3. Un bon indicateur (section 18.3).
4. Le tableau de bord (section 18.4).
5. De la mesure à la décision (section 18.5).

© *MaletYon*

18.1 L'Exigence de Mesure

Définition

La clause 9.1 de [ISO/IEC 27001] exige de déterminer *quoi* surveiller et mesurer, *comment*, *quand* et *qui* analyse les résultats. La norme [ISO/IEC 27004] en donne les lignes directrices.

Mesurer n'est pas accumuler des chiffres : c'est choisir les quelques indicateurs qui éclairent une décision. Un bon dispositif de mesure est sélectif.

18.2 Performance et Risque

Définition

Un **indicateur de performance** (KPI) mesure l'efficacité d'une mesure (taux d'agents formés). Un **indicateur de risque** (KRI) alerte sur une exposition croissante (nombre de comptes sans MFA).

Les deux se complètent : les KPI disent « où en est-on », les KRI disent « où le danger monte ». Un tableau de bord équilibré comporte les deux.

18.3 Un Bon Indicateur

Qualité	Signification
Mesurable	On peut le calculer objectivement
Pertinent	Il éclaire une décision réelle
Suivi	Il est relevé à intervalle régulier
Doté d'une cible	On sait ce qui est bon ou mauvais
Attribué	Quelqu'un en répond

Tableau 18.1. Qualités d'un bon indicateur

Un indicateur que personne ne regarde ou qui ne change aucune décision est à supprimer : il coûte sans servir.

18.4 Le Tableau de Bord

Indicateur	Type	Cible	État
Agents formés	KPI	100 %	80 %
Sauvegardes testées	KPI	Mensuel	À jour
Comptes sans MFA	KRI	0	5
Incidents du mois	KRI	–	2

Tableau 18.2. Extrait du tableau de bord de la mairie

Application RSSI

Un tableau de bord pour décider. La RSSI présente au comité un tableau d'une page, lisible par un non-technicien. Chaque indicateur hors cible appelle une décision : former les agents restants, activer la MFA manquante. Le tableau de bord n'est pas un rapport : c'est un outil de pilotage.

18.5 De la Mesure à la Décision

Mesure

Constatation. Le tableau de bord montre 5 comptes sans MFA et un taux de formation de 80 %.

Analyse. Deux écarts à la cible appellent deux décisions : activer la MFA sur les cinq comptes, achever la formation des agents restants. La mesure débouche sur l'action : c'est le lien entre « Check » et « Act » du PDCA (Chapitre 3).

La mesure alimente la revue de direction et l'audit (Chapitre 19) : elle fournit les preuves chiffrées que le SMSI fonctionne et s'améliore.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La **clause 9.1** exige de mesurer quoi, comment, quand et par qui.
- Les **KPI** mesurent la performance ; les **KRI** alertent sur le risque.
- Un **bon indicateur** est mesurable, pertinent, suivi, doté d'une cible, attribué.
- Le **tableau de bord** est un outil de pilotage, lisible par la direction.
- La **mesure débouche sur la décision** et nourrit l'audit.

Note

Points de contrôle de l'élève. Je sais : énoncer l'exigence de la clause 9.1 ; distinguer KPI et KRI ; reconnaître un bon indicateur ; bâtir un tableau de bord ; relier mesure et décision.

✍ Exercice 18.1. Quoi mesurer ★☆☆

Que doit déterminer la clause 9.1 au sujet de la mesure ?

✍ Exercice 18.2. KPI ou KRI ★☆☆

« Taux d'agents formés » et « comptes sans MFA » : lequel est un KPI, lequel un KRI ?

✍ Exercice 18.3. Bon indicateur ★☆☆

Citez trois qualités d'un bon indicateur.

✍ Exercice 18.4. Indicateur inutile ★★☆

Pourquoi supprimer un indicateur que personne ne regarde ?

✍ Exercice 18.5. Construire un KPI ★★☆

Construisez un KPI pour la mesure « sauvegarde de l'état civil ».

✍ Exercice 18.6. Hors cible ★★☆

Pour chaque indicateur hors cible du tableau de bord, proposez une décision.

✍ Exercice 18.7. Lisible ★★☆

Pourquoi le tableau de bord doit-il être lisible par un non-technicien ?

✍ Exercice 18.8. Check et Act ★★☆

Montrez que la mesure relie les étapes Check et Act du PDCA.

✍ Exercice 18.9. Tableau de bord ★★★

Construisez un tableau de bord de six indicateurs pour la mairie d'Eséka (type, cible, responsable).

✍ Exercice 18.10. Note de pilotage ★★★

Rédigez la note mensuelle de pilotage que la RSSI présente au comité de sécurité.

Note

Pour aller plus loin.

➢ ISO/IEC 27004 [8] ; ISO/IEC 27001, clause 9.1 [10].

Note

Transition. Mesurer soi-même ne suffit pas : il faut un regard extérieur. Le Chapitre 19 traite l'audit et la certification.

19

L'AUDIT DU SMSI ET LA CERTIFICATION

« L'audit ne cherche pas le coupable :
il cherche l'écart entre ce qui est dit et ce qui est fait. »

Principe du cours

Niveau : *Intermédiaire* • Le Chapitre 18.

✦ Objectifs du chapitre

- ➢ Distinguer audit interne et audit de certification.
- ➢ Décrire la méthodologie d'audit (ISO 19011).
- ➢ Caractériser constat, preuve, non-conformité et écart.
- ➢ Expliquer la revue de direction.
- ➢ Décrire le cycle de certification [ISO/IEC 27001].

Question directrice : comment faire reconnaître que la sécurité est maîtrisée ?

La mairie pense son SMSI solide. Un audit le vérifie, et la certification l'atteste. Ce chapitre présente l'audit, la revue de direction et le chemin vers la certification.

Plan du chapitre.

1. Les types d'audit (section 19.1).
2. La méthodologie (section 19.2).
3. Constat, preuve, écart (section 19.3).
4. La revue de direction (section 19.4).
5. Le cycle de certification (section 19.5).

© MaletYon

19.1 Les Types d'Audit

Type	Qui et pourquoi
Audit interne	Mené par l'organisation, exigé par la clause 9.2
Audit de seconde partie	Mené par un client ou une tutelle
Audit de certification	Mené par un organisme accrédité (tierce partie)

Tableau 19.1. Les types d'audit

L'**audit interne** prépare : il détecte les écarts avant l'auditeur externe. L'**audit de certification** atteste, auprès des tiers, que le SMSI satisfait la norme.

19.2 La Méthodologie

La norme [ISO 19011] guide l'audit des systèmes de management : planification, revue documentaire, entretiens et observations sur site, rédaction du rapport, suivi des actions. L'auditeur est **indépendant** de ce qu'il audite et procède par **échantillonnage**.

Mesure

Constatation. Pour l'opération MATOMB, le cabinet MATOMB CONSEIL conduit l'audit interne de la mairie avant la certification.

Analyse. L'audit interne est une répétition générale : il cherche les écarts pendant qu'il est encore temps de les corriger. Un écart trouvé en interne se corrige ; le même écart trouvé en certification coûte un report.

19.3 Constat, Preuve, Écart

Définition

Preuve d'audit : enregistrement vérifiable (document, observation, déclaration). **Constat** : résultat de l'évaluation des preuves face à un critère. **Non-conformité** : écart entre l'exigence et la réalité, *majeure* (défaillance du système) ou *mineure* (manquement isolé).

L'auditeur sépare le *fait* (ce qu'il constate, preuve à l'appui) de son *appréciation*. Cette rigueur, qui distingue la constatation de l'analyse, est au cœur du métier d'auditeur [15].

Application Auditeur SMSI

Pas de constat sans preuve. L'auditeur ne note jamais une impression : il adosse chaque constat à une preuve (un document, un relevé, une observation). Un écart sans preuve n'est pas un écart : c'est un avis.

19.4 La Revue de Direction

■ Définition

Revue de direction (clause 9.3) : examen périodique du SMSI par la direction, qui passe en revue les résultats des audits, des mesures et des incidents, et décide des améliorations et des ressources.

La revue de direction est le moment où la direction *reprend la main* : elle transforme les constats en décisions. Sans elle, l'audit resterait sans suite. À Eséka, le maire la préside deux fois par an.

19.5 Le Cycle de Certification

Étape	Contenu
Audit initial (étape 1)	Revue documentaire, préparation
Audit initial (étape 2)	Audit sur site, décision de certification
Audits de surveillance	Chaque année, maintien du certificat
Renouvellement	Au bout de trois ans, nouvel audit complet

Tableau 19.2. Le cycle de certification ISO/IEC 27001

La certification se *gagne* en deux étapes et se *maintient* par des audits de surveillance. Elle n'est pas acquise une fois pour toutes : le SMSI doit continuer de tourner (Chapitre 3).

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- L'**audit interne** prépare ; l'**audit de certification** atteste.
- La **méthodologie** (ISO 19011) procède par preuves, échantillonnage et indépendance.
- Un **constat** s'adosse à une **preuve** ; une **non-conformité** est majeure ou mineure.
- La **revue de direction** transforme les constats en décisions.
- La **certification** se gagne en deux étapes et se maintient par surveillance.

Note

Points de contrôle de l'élève. Je sais : distinguer les types d'audit ; décrire la méthodologie ; définir preuve, constat, non-conformité ; expliquer la revue de direction ; décrire le cycle de certification.

✍ Exercice 19.1. Types d'audit ★☆☆

Distinguez audit interne et audit de certification.

✍ Exercice 19.2. Preuve ★☆☆

Qu'est-ce qu'une preuve d'audit ? Donnez deux exemples.

✍ Exercice 19.3. Le cycle ★☆☆

Énoncez les étapes du cycle de certification [ISO/IEC 27001].

✍ Exercice 19.4. Majeure ou mineure ★★☆

Distinguez une non-conformité majeure d'une mineure, par un exemple à la mairie.

✍ Exercice 19.5. Répétition générale ★★☆

Pourquoi l'audit interne est-il une « répétition générale » ?

✍ Exercice 19.6. Constat sans preuve ★★☆

Pourquoi un écart sans preuve n'est-il qu'un avis ?

✍ Exercice 19.7. Indépendance ★★☆

Pourquoi l'auditeur doit-il être indépendant de ce qu'il audite ?

✍ Exercice 19.8. Revue de direction ★★☆

Que décide la direction lors de la revue, et à partir de quoi ?

✍ Exercice 19.9. Plan d'audit ★★★

Rédigez le plan d'audit interne du SMSI de la mairie d'Eséka (périmètre, critères, étapes).

✍ Exercice 19.10. Fiche d'écart ★★★

Rédigez une fiche de non-conformité (constat, preuve, exigence, gravité, action corrective) pour un écart de la mairie.

Note

Pour aller plus loin.

➢ ISO 19011 [4] ; ISO/IEC 27006 [7] ; auditologie [15].

Note

Transition. Reste le dernier maillon du cycle : apprendre des incidents. Le Chapitre 20 clôt le cours.

20

GÉRER LES INCIDENTS ET PROGRESSER

« Un incident bien géré n'est pas un échec :
c'est le moment où le système apprend. »

Principe du cours

Niveau : *Intermédiaire* • La partie VI.

✦ Objectifs du chapitre

- ➢ Décrire le processus de gestion des incidents.
- ➢ Classer et prioriser un incident.
- ➢ Conduire un retour d'expérience (RETEX).
- ➢ Relier l'incident à l'amélioration continue (clause 10).
- ➢ Mesurer les progrès du SMSI dans la durée.

Question directrice : comment transformer un incident en progrès ?

L'histoire de la mairie a commencé par un incident. Ce dernier chapitre montre comment un SMSI gère les incidents et s'en sert pour progresser, bouclant le cycle du cours.

Plan du chapitre.

1. Le processus de gestion (section 20.1).
2. Classer et prioriser (section 20.2).
3. Le retour d'expérience (section 20.3).
4. L'incident, moteur d'amélioration (section 20.4).
5. Mesurer les progrès (section 20.5).

© MaletYon

20.1 Le Processus de Gestion

Définition

La **gestion des incidents** : processus qui détecte, signale, qualifie, traite et clôt les incidents de sécurité, en tirant les leçons de chacun ([ISO/IEC 27035]).

Étape	Contenu
Détecter et signaler	Repérer et alerter, sans crainte de sanction
Qualifier	Confirmer l'incident, en mesurer la portée
Traiter	Contenir, éradiquer, rétablir
Clore et apprendre	Documenter et conduire le RETEX

Tableau 20.1. Le processus de gestion des incidents

Le signalement est la clé : un incident tu ne peut être traité. La culture du signalement sans blâme, posée à la sensibilisation (Chapitre 15), porte ici ses fruits.

20.2 Classer et Prioriser

Mesure

Constatation. La mairie reçoit deux signalements : un courriel d'hameçonnage non ouvert, et un poste d'état civil qui redémarre seul.

Analyse. On classe selon l'*impact* et l'*urgence* : le courriel non ouvert est mineur (surveiller) ; le poste d'état civil qui redémarre touche un actif critique (priorité haute, isoler et investiguer). Prioriser, c'est mettre les moyens là où l'enjeu est le plus fort.

20.3 Le Retour d'Expérience

Définition

Retour d'expérience (RETEX) : analyse, après un incident, de ce qui s'est passé, de ce qui a bien ou mal fonctionné, et des améliorations à apporter. Il vise la cause, non le coupable.

Le RETEX de l'incident initial de la mairie a produit des mesures durables : interdiction des clés personnelles, sauvegardes 3-2-1, comptes nominatifs, sensibilisation. L'incident, bien analysé, a été le point de départ de tout le SMSI.

Application RSSI

Chercher la cause, pas la faute. La RSSI conduit le RETEX dans un esprit d'amélioration : on cherche pourquoi le système a permis l'incident, non qui a cliqué. Un RETEX accusateur tarit les signalements ; un RETEX constructif les encourage.

20.4 L'Incident, Moteur d'Amélioration

L'incident alimente la clause 10 (amélioration) : chaque RETEX génère des actions correctives qui éliminent des causes, et parfois des améliorations qui renforcent au-delà. C'est le « Act » du PDCA : on referme la boucle et l'on relance un cycle plus mûr.

20.5 Mesurer les Progrès

Actif · Le SMSI de la mairie, un an après

Constatation. Un an après l'incident, la mairie a : une politique signée, des risques appréciés, des mesures déployées, un tableau de bord, un audit interne passé, une certification en vue.

Analyse. Le progrès se mesure : délai de reprise réduit, sauvegardes testées, agents formés, incidents mieux traités. La mairie ne promet pas le risque zéro ; elle démontre un risque *maîtrisé*. C'est l'aboutissement du cours : non pas un système parfait, mais un système qui apprend.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La **gestion des incidents** détecte, signale, qualifie, traite et clôt.
- On **classe** et **priorise** selon l'impact et l'urgence.
- Le **RETEX** cherche la cause, non le coupable.
- L'incident nourrit l'**amélioration continue** (clause 10).
- Le progrès se **mesure** : un SMSI mûr maîtrise le risque, sans l'annuler.

Note

Points de contrôle de l'élève. Je sais : décrire le processus de gestion des incidents ; classer et prioriser ; conduire un RETEX ; relier l'incident à l'amélioration ; mesurer les progrès du SMSI.

✍ Exercice 20.1. Le processus ★☆☆

Énoncez les quatre étapes de la gestion des incidents.

✍ Exercice 20.2. Signaler ★☆☆

Pourquoi le signalement sans blâme est-il essentiel ?

✍ Exercice 20.3. RETEX ★☆☆

Qu'est-ce qu'un retour d'expérience, et que vise-t-il ?

✍ Exercice 20.4. Prioriser ★★☆

Entre le courriel non ouvert et le poste qui redémarre, lequel traiter d'abord ? Pourquoi ?

✍ Exercice 20.5. Cause ou faute ★★☆

Pourquoi un RETEX accusateur tarit-il les signalements ?

✍ Exercice 20.6. Incident et clause 10 ★★☆

Comment un incident alimente-t-il l'amélioration continue ?

✍ Exercice 20.7. L'incident fondateur ★★☆

Montrez comment l'incident initial de la mairie a produit des mesures durables.

✍ Exercice 20.8. Mesurer le progrès ★★☆

Citez trois indicateurs montrant que le SMSI de la mairie a progressé.

✍ Exercice 20.9. Procédure d'incident ★★★

Rédigez la procédure de gestion des incidents de la mairie d'Eséka (détection à clôture).

✍ Exercice 20.10. RETEX complet ★★★

Conduisez le RETEX écrit de l'incident initial de la mairie (déroulé, causes, actions correctives, améliorations).

● Note

Pour aller plus loin.

➢ ISO/IEC 27001, clause 10 [10] ; auditologie [15].

Note

Clôture du cours. De l'incident à la certification, la mairie d'Eséka a appris à *décider* sa sécurité, à la *tenir* dans la durée et à la *prouver*. Tel est le management de la sécurité de l'information : non pas un état que l'on atteint, mais une roue que l'on fait tourner. Planifier, déployer, contrôler, agir : et recommencer, un cran plus haut.

A

GLOSSAIRE

Ce glossaire reprend les notions définies dans les chapitres. Le renvoi indique le chapitre où la notion est présentée.

Actif Élément de valeur pour l'organisation, qu'il faut protéger (Ch. 1).

Appétence au risque Niveau de risque qu'une organisation est prête à accepter (Ch. 11).

Appréciation des risques Démarche d'identification, d'analyse et d'évaluation des risques (Ch. 12).

Déclaration d'applicabilité (DdA) Document indiquant, pour chaque mesure de l'Annexe A, si elle est retenue, sa justification et son état (Ch. 14).

Disponibilité, Intégrité, Confidentialité (DIC) Les trois critères fondamentaux de la sécurité de l'information (Ch. 1).

Gouvernance de la sécurité Responsabilités et pratiques par lesquelles la direction oriente la sécurité (Ch. 4).

Mesure de sécurité Moyen (organisationnel, humain, physique, technique) de traiter un risque (Ch. 10).

Non-conformité Écart entre une exigence et la réalité, majeure ou mineure (Ch. 19).

Partie intéressée Personne ou organisme ayant une attente vis-à-vis du SMSI (Ch. 8).

PCA / PRA Plan de continuité d'activité ; plan de reprise d'activité (Ch. 17).

PDCA Cycle Planifier-Déployer-Contrôler-Agir, moteur de l'amélioration continue (Ch. 3).

Politique de sécurité (PSSI) Document fondateur fixant objectifs, règles et responsabilités (Ch. 5).

Revue de direction Examen périodique du SMSI par la direction, qui décide des améliorations (Ch. 19).

Risque Combinaison de la probabilité d'un événement et de son impact (Ch. 11).

Risque résiduel Risque subsistant après traitement, accepté par la direction (Ch. 13).

RTO / RPO Délai de reprise visé ; perte de données maximale acceptable (Ch. 17).

SMSI Système de management de la sécurité de l'information (Ch. 0).

Vraisemblance Probabilité qu'un risque se réalise (Ch. 11).

B

RÉFÉRENTIEL DES OUTILS

Les outils et modèles cités sont des exemples. Le cours insiste sur la méthode : l'outil sert la décision, il ne la remplace pas.

Outil ou modèle	Usage	Chapitre, lab
Inventaire des actifs	Recenser et classer l'information	Ch. 1, SGSI-LAB-01
Modèle de politique	Rédiger la PSSI	Ch. 5, SGSI-LAB-02
Grille d'écart ISO 27001	Mesurer la maturité (gap analysis)	Ch. 8, SGSI-LAB-03
Méthode EBIOS RM	Apprécier les risques	Ch. 12, SGSI-LAB-04
Matrice des risques	Hiérarchiser et traiter	Ch. 13, SGSI-LAB-05
Modèle de DdA	Relier risques et mesures	Ch. 14, SGSI-LAB-06
Matrice RBAC	Contrôler les accès par rôle	Ch. 16, SGSI-LAB-07
Plan de continuité	Sauvegarde 3-2-1, RTO/RPO	Ch. 17, SGSI-LAB-08
Tableau de bord	Suivre les indicateurs	Ch. 18, SGSI-LAB-09
Fiche de non-conformité	Conduire un audit interne	Ch. 19, SGSI-LAB-10

★ Attention

Rappel. Une mesure ne se retient que si un risque la justifie. Le catalogue de l'Annexe A n'est pas une liste à appliquer en bloc : c'est une réponse au risque apprécié.

© MaletYon

C

MODÈLES ET PROCÉDURES

Fiche d'actif

Rubrique	Contenu
Actif	Information et support
Propriétaire	Qui en répond
Valeur / classification	Niveau de sensibilité
Critères prioritaires	D, I, C

Ligne de déclaration d'applicabilité

Rubrique	Contenu
Mesure (Annexe A)	Intitulé de la mesure
Retenue	Oui / non
Justification	Risque couvert ou motif d'exclusion
État	En place, en cours, planifiée

Fiche de risque

Rubrique	Contenu
Actif et menace	Ce qui est visé, par quoi
Vulnérabilité	La faiblesse exploitée
Probabilité / impact	Niveaux estimés
Traitement	Stratégie, mesure, responsable
Risque résiduel	Niveau, acceptation

Plan d'une politique de sécurité (PSSI)

1. Introduction et contexte (objectifs, portée, références).
2. Gouvernance (organisation, rôles, comité).
3. Classification et manipulation de l'information.

4. Contrôle d'accès.
5. Sécurité des opérations (sauvegarde, journalisation, incidents).
6. Conformité (audits, revue, sanctions).

D

TEXTES JURIDIQUES ET NORMATIFS

Seuls les éléments vérifiés dans le texte officiel sont cités dans les chapitres. Ce tableau indique où les trouver.

Droit camerounais et africain

Texte	Objet	Chapitre
Loi n° 2010/012 du 21 déc. 2010	Cybersécurité et cybercriminalité	2
Loi n° 2024/017 du 23 déc. 2024	Protection des données personnelles	6
Convention de Malabo (UA, 2014)	Cybersécurité et données, Afrique	6

Normes et référentiels internationaux

Référence	Objet	Chapitre
ISO/IEC 27000	Vocabulaire et vue d'ensemble	7
ISO/IEC 27001	Exigences du SMSI	7
ISO/IEC 27002	Mesures de sécurité	10
ISO/IEC 27005	Gestion des risques	12
ISO 31000	Management du risque	11
ISO 22301	Continuité d'activité	17
ISO 19011	Audit des systèmes de management	19
NIST CSF 2.0	Cadre de cybersécurité	7
EBIOS Risk Manager (ANSSI)	Appréciation des risques	12

© *MaletYon*

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures. Les références complètes figurent dans la bibliographie du livre.

Partie I · Fondements du management

- ISO/IEC 27000 [9] : vocabulaire et vue d'ensemble.
- ISO/IEC 27001 [10] : l'approche processus et le PDCA.
- ISO 31000 [5] : le management du risque.

Partie II · Gouvernance et politique

- COBIT 2019 [3] : la gouvernance du SI.
- Lois 2010/012 [13] et 2024/017 [14] ; Malabo [17].
- Guide d'hygiène ANSSI [1].

Partie III · Le SMSI ISO/IEC 27001

- ISO/IEC 27001 [10] : les clauses 4 à 10.
- ISO/IEC 27002 [11] : les mesures de l'Annexe A.
- NIST CSF 2.0 [16] : un cadre complémentaire.

Partie IV · Les risques

- ISO/IEC 27005 [12] : la gestion des risques.
- EBIOS Risk Manager [2] : la méthode par scénarios.

Parties V et VI · Mise en œuvre, contrôle et audit

- ISO 22301 [6] : la continuité d'activité.
- ISO 19011 [4] ; ISO/IEC 27006 [7] : l'audit et la certification.
- ISO/IEC 27004 [8] : la mesure ; auditologie [15].

© *MaletYon*

F

CONTACTS ET RESSOURCES

Les adresses sont celles des sites institutionnels à la date de rédaction ; à vérifier.

Organisation	Rôle	Site
ANTIC	Sécurité électronique, CERT national (Cameroun)	`www.antic.cm`
Union africaine	Convention de Malabo	`au.int`
ISO	Normes ISO et ISO/IEC	`www.iso.org`
NIST	Cadre de cybersécurité, SP 800	`www.nist.gov`
ANSSI	EBIOS RM, guide d'hygiène	`cyber.gouv.fr`
ISACA	COBIT, certifications	`www.isaca.org`

● Note

La plateforme du cours. Les fiches d'auto-évaluation et les dix labs de NDAP SUKULU pour ce cours sont accessibles par le code `SIS498`.

© *MaletYon*

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] ANSSI, *Guide d'hygiène informatique · Renforcer la sécurité de son système d'information en 42 mesures*, Agence nationale de la sécurité des systèmes d'information, Paris, 2017.

[2] ANSSI, *EBIOS Risk Manager · La méthode d'appréciation et de traitement des risques numériques*, Agence nationale de la sécurité des systèmes d'information, Paris, 2018.

[3] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*, ISACA, Schaumburg, IL, 2018.

[4] ISO, *ISO 19011:2018 · Lignes directrices pour l'audit des systèmes de management*, International Organization for Standardization, Genève, 2018.

[5] ISO, *ISO 31000:2018 · Management du risque · Lignes directrices*, International Organization for Standardization, Genève, 2018.

[6] ISO, *ISO 22301:2019 · Sécurité et résilience · Systèmes de management de la continuité d'activité · Exigences*, International Organization for Standardization, Genève, 2019.

[7] ISO/IEC, *ISO/IEC 27006:2015 · Requirements for bodies providing audit and certification of information security management systems*, International Organization for Standardization, Genève, 2015.

[8] ISO/IEC, *ISO/IEC 27004:2016 · Information security management · Monitoring, measurement, analysis and evaluation*, International Organization for Standardization, Genève, 2016.

[9] ISO/IEC, *ISO/IEC 27000:2018 · Information technology · Security techniques · Information security management systems · Overview and vocabulary*, International Organization for Standardization, Genève, 2018.

[10] ISO/IEC, *ISO/IEC 27001:2022 · Information security, cybersecurity and privacy protection · Information security management systems · Requirements*, International Organization for Standardization, Genève, 2022.

[11] ISO/IEC, *ISO/IEC 27002:2022 · Information security, cybersecurity and privacy protection · Information security controls*, International Organization for Standardization, Genève, 2022.

[12] ISO/IEC, *ISO/IEC 27005:2022 · Information security, cybersecurity and privacy protection · Guidance on managing information security risks*, International Organization for Standardization, Genève, 2022.

[13] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*, 21 déc. 2010.

[14] *Loi n° 2024/017 du 23 décembre 2024 régissant la protection des données à caractère personnel au Cameroun*, 23 déc. 2024.

[15] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. (22 juill. 2026), adresse : https://hal.science/hal-05701007.

[16] National Institute of Standards and Technology, « The NIST Cybersecurity Framework (CSF) 2.0, » National Institute of Standards et Technology, NIST Cybersecurity White Paper CSWP 29, 2024.

[17] Union africaine, *Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel (Convention de Malabo)*, Union africaine, Malabo, 2014.

INDEX

EBIOS Risk Manager, 76
MEHARI, 76
OCTAVE, 76
3-2-1, 106

accepte formellement, 83
acceptent, 89
Accepter, 82
Actif, 10, 72
Action corrective, 23
actions face aux risques et opportunités, 57
agir, 22
Amélioration, 23
amélioration continue, 63
Analyse d'impact sur l'activité, 106
Annexe A, 66
appliquée, 37
appréciation des risques, 62, 66
Appétence au risque, 72
arrivée, 95
attributs, 66
audit de certification, 116
audit interne, 116
Authenticité, 11
Authentification multifacteur, 100

cause, 4
Certification **[ISO/IEC 27001]**, 51
charte, 37
Charte informatique, 42
Chiffrement, 101
comité de sécurité, 30
communication, 62
compétences, 62
Confidentialité, 10
Constat, 116
continuité du service public, 16
contrôler, 22
Correction, 23
critères d'acceptation, 72
cycle PDCA, 22

diffusée, 37
Disponibilité, 10
domaine d'application, 56
décider, 17
déclaration d'applicabilité, 67, 88
Délégué à la protection des données, 43
démontre, 56
départ, 95
déployer, 22

enjeux internes et externes, 56
exigences, 50

facteur humain, 94

gestion des incidents, 122
Gouvernance de la sécurité, 30
guide de mise en œuvre, 66

Impact, 72
indicateur de performance, 112
indicateur de risque, 112
indépendant, 116
Information, 10
Information documentée, 62
informations documentées, 62
Intégrité, 10

Journalisation, 101

leadership, 31
lignes directrices, 50

management de la sécurité, 4
matrice des risques, 82
Menace, 72
mobilité, 95
moindre privilège, 100

© *MaletYon*

Non-conformité, 116
non-conformités, 63
Non-répudiation, 11

objectif de sécurité, 57
objectifs de sécurité, 57

parties intéressées, 17, 56
Patrimoine informationnel, 17
Plan de continuité d'activité, 106
Plan de reprise d'activité, 106
plan de traitement, 82
plan de traitement des risques, 88
planifier, 22
planifier et maîtriser, 62
politique, 37
Politique de sécurité du système d'information, 36
portée, 36
Preuve d'audit, 116
Probabilité, 72
processus d'appréciation et de traitement des risques, 57
procédure, 37
propriétaires des risques, 89

RACI, 31
ressources, 62
Retour d'expérience, 122
Revue de direction, 117
risque, 72
Risque inhérent, 72
Risque résiduel, 72
risque résiduel, 83
roue, 5
rédigée, 37
Réduire, 82
révisée, 37

segmentation, 100
sensibilisation, 62
stratégies de traitement, 82
Système de management de la sécurité de l'information, 4
système de management de la sécurité de l'information, 4
sécurité de l'information, 11
sécurité informatique, 11

traitement des risques, 62
Transférer, 82
Traçabilité, 11
triade DIC, 10

validée, 37
Vulnérabilité, 72

Éviter, 82
échantillonnage, 116

À propos de ce cours

Quand un système d'information s'arrête, la question décisive n'est pas technique : elle porte sur qui avait décidé, et qui devait rendre compte. Ce cours apprend à y répondre avant la panne.

Il progresse en six parties, précédées d'un prologue : les fondements de la gouvernance des systèmes d'information, le référentiel COBIT 2019, le cadre normatif et juridique, ITIL 4 et les processus de gestion des services, les défis de l'agilité, du nuage et de l'intelligence artificielle, et enfin la recherche.

Chaque notion est ancrée à la fois dans les standards internationaux (ISO, ISACA, IIA, INTOSAI) et dans le droit camerounais et communautaire (CEMAC, OHADA). Le cours s'adresse aux étudiants du Master Professionnel en Management des Systèmes d'Information et aux professionnels qui exercent comme DSI, responsables GRC, auditeurs des SI, responsables des services informatiques ou RSSI.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information